

NHID-CLINICAL MASTER KNOWLEDGE ARCHIVE

Version: 1.0

Compiled: 2026-06-12

Source: NHID-Clinical-SaaS repository (private) + nhid-clinical/ open proposal (CC BY 4.0)

Author of underlying work: Brianna Baynard | contact@nhid-clinical.org

NIST Comment Reference: NIST-2025-0035-0026

Repository: <https://github.com/nhid-clinical/nhid-clinical-saas> (private)

Public Reference: <https://github.com/thankcheeses/NHID-Clinical> | <https://nhid-clinical.org>

Archive Status: *This document is the consolidated master knowledge base derived from 100% of source material in the NHID-Clinical-SaaS repository as of 2026-06-12. All claims are traceable to source files. Inferred content is labeled `[Inferred]`. Missing or incomplete content is labeled `[Missing]` or `[Open Question]`.*

Table of Contents

1. Executive Vision & Strategic Direction
2. NHID-Clinical Core Framework
3. Governance Architecture
4. Identity & Trust Infrastructure
5. Healthcare AI Agent Verification
6. Technical Architecture
7. Implementation Roadmap
8. Coding & Development
9. Claude Code, Manus, Perplexity, ChatGPT, Grok, Kimi, or Other LLM Tasking
10. Website Content
11. Whitepaper Content

- 12. Diagrams & Visual Concepts
 - 13. Research References
 - 14. Regulatory & Federal Alignment
 - 15. NIST References
 - 16. CMS References
 - 17. Sponsorship & Partnership Discussions
 - 18. Marketing & Positioning
 - 19. Decisions Made
 - 20. Future Work
 - 21. Templates & Checklists
 - 22. FAQ & Plain Language Guide
 - 23. Source Material Appendix
-

1. Executive Vision & Strategic Direction

1.1 Origin Story

NHID-Clinical was created by Brianna Baynard, built directly from experience enforcing HIPAA compliance in actual payer operations. The observation that triggered it: AI voice agents were calling insurance company offices, providing authentication details, collecting protected operational data -- and only disclosing their non-human identity when challenged, sometimes 3-5 minutes into a call. Payer staff had no standard for what a legitimate AI call looked like, so they defaulted to a blanket termination policy: "We do not speak with AI agents. Please have a human representative call back."

This cycle -- the AI calls, gets terminated, calls back, gets terminated again -- happens thousands of times per day across U.S. healthcare. There was no written-down answer to what an acceptable AI-initiated call even looks like.

The open proposal (NHID-Clinical, CC BY 4.0) was filed as a public comment with NIST (NIST-2025-0035-0026). The private SaaS layer (NHID-Clinical-SaaS) is the commercial enforcement platform built on top of that proposal.

Source: [nhid-clinical/README.md](#) , [attached_assets/Pasted--NHID-Clinical-v1-3-*](#)

1.2 Mission Statement

Define a minimum control baseline for non-human identity disclosure in B2B healthcare voice interactions -- and provide a hosted enforcement platform that makes compliance testable, auditable, and commercially deployable.

Plain language: Make it clear, fast, and verifiable when an AI is calling a health insurance company. Stop the guessing game that wastes everyone's time.

1.3 Vision

A healthcare system where:

- Every AI voice agent operating in B2B administrative workflows identifies itself before asking for any data
 - Payer staff can verify AI caller authorization from a trusted registry
 - Compliance is provable via cryptographic audit trails
 - AI-vs-AI friction is replaced by a "Green Lane" that benefits providers, payers, and patients
-

1.4 Product Thesis

The NHID-Clinical SaaS platform is a **multi-tenant AI governance layer** that sits in front of any voice AI platform (Twilio, Retell AI, Vapi, or custom) and enforces disclosure, escalation, and audit requirements in real time. It is:

- Sold as a tiered subscription (Free / L1 / L2 / L3)
 - Backed by HMAC-SHA256 tamper-evident audit logging
 - Integrated with Stripe for billing
 - Positioned as the compliance backbone for healthcare AI voice deployments
-

1.5 Target Users

User Type	Role	Need
AI voice platform vendors (Retell, Vapi, etc.)	Technical integrators	Drop-in governance webhook

User Type	Role	Need
Provider-side AI teams	Healthcare IT	Compliance proof for payer calls
Payer operations staff	Compliance / IT	Standard for accepting AI calls
Healthcare compliance officers (HIPAA, state)	Governance	Auditable evidence of disclosure
Engineering teams building healthcare AI	Developers	SDK and policy engine

1.6 Problem Statement

"Impersonation Latency" -- the operational waste and security risk caused when a human provider cannot immediately distinguish an AI agent from a human counterpart.

What actually happens today:

1. AI provides authentication details (NPI, Member ID) before identifying itself as automated
2. Payer rep shares protected operational data -- claim status, eligibility, appeal details
3. Disclosure happens only when challenged, 3-5 minutes in
4. Even after disclosure, there is no way to verify the AI is authorized by the provider it claims to represent
5. Payer terminates call; AI calls back; cycle repeats
6. Deceptive artifacts (fake breathing, typing sounds, scripted "umm") make detection harder
7. Blanket rejection: "We do not speak with AI agents"

Compound effect: AI-vs-AI friction is increasing administrative costs, not reducing them. The Peterson Health Technology Institute (April 2026) found that while AI speeds up individual tasks, it does not lower the average cost per claim once AI solution costs are factored in.

1.7 Market Context

- U.S. health system administrative complexity costs \$350 billion annually (Health Affairs, 2025)
- AI deployment in prior authorization and billing has created "adversarial AI friction"
- Transaction volume inflation: a single claim now cycles through 3-4x more automated loops (appeals, resubmissions, denials) than in 2024
- Verification overhead: payers allocate 30-40% of administrative time for complex claims to human oversight of AI-generated billing and appeals
- 82% overturn rate in Medicare Advantage prior auth appeals as of Q2 2026

- New AI governance liability: insurance and legal exposure for AI systems that deny necessary care

Source: [attached_assets/Pasted--NHID-Clinical-v1-3-*](#) (Peterson Health Technology Institute reference, Health Affairs 2025 reference)

1.8 Strategic Priorities

1. **Establish the open standard** -- NHID-Clinical v1.3 as the reference governance layer (public, CC BY 4.0)
2. **Deploy the enforcement platform** -- NHID-Clinical SaaS as the hosted commercial product
3. **Close the authorization gap** -- NHID-Auth v1.0 companion spec (delegated authority for AI voice agents)
4. **Build the registry** -- Live public verification layer for certified implementations (v1.4+)
5. **Seek pilot validations** -- First certifications offered at no cost to AI voice agent platforms in healthcare
6. **Maintain test fidelity** -- 43-pass NHID core test suite must remain intact through all SaaS evolution

1.9 Success Criteria

Metric	Definition	Target
Disclosure Failure Rate (DFR)	Calls where data was requested before disclosure	< 2%
Escalation Loop Frequency	Callers repeating "Agent" or "Representative" >2x	< 1 per 100 calls
Average Handle Time (AHT)	Reduction by eliminating verification loops	-15 to -30 seconds
Provider Satisfaction	Post-interaction feedback	> 85% Positive
NHID Core Test Suite	Passing tests in nhid-clinical/	43/0/0 always

2. NHID-Clinical Core Framework

2.1 Plain Language Summary

What is this? A rulebook for AI voice agents calling health insurance companies. Four behaviors are required: (1) say you're a robot before asking for anything, (2) no fake human sounds, (3) immediately hand off to a human when asked, (4) keep a log of what happened.

Why does it matter? Insurance companies are currently hanging up on AI callers because they have no standard for telling good AI from bad AI. This framework creates that standard.

Who uses it? AI voice platform vendors, healthcare IT teams, compliance officers, and anyone building or operating AI agents that call payers.

2.2 Core Concepts

NHID = Non-Human Identity Disclosure. The requirement that AI agents proactively identify themselves before any data exchange.

Impersonation Latency = The delay between when an AI begins operating and when it discloses its non-human identity. The primary failure mode NHID-Clinical addresses.

The Green Lane = When AI agents follow NHID-Clinical rules, calls are faster and more trusted for all parties.

B2B Administrative Workflows = The scope of NHID-Clinical v1.3. Provider-to-Payer and Business Associate-to-Payer calls only. Does NOT cover direct-to-consumer or patient-facing clinical triage.

2.3 The Four Behaviors (Normative Requirements)

These are stated using RFC 2119 MUST/MUST NOT/SHOULD/MAY terminology.

1. Proactive Identity Assertion (PIA) -- IDG-01

AI MUST state "I am an automated system" (or equivalent) before any exchange of operational data (NPI, Member ID, Claim Number, or equivalent identifiers).

2. No Deceptive Artifacts -- DBC-01 ("The Turing Boundary")

AI agents **MUST NOT** use simulated presence cues (breathing sounds, typing, artificial hesitation) designed to imply human presence. Natural speech pacing and prosody are permitted.

3. Clear Escalation Path -- EIT-01

When a human stakeholder explicitly requests a transfer: (a) immediately acknowledge, (b) preserve context with a reference number, (c) transfer immediately if staff available, (d) state hours + offer callback if after hours.

4. Audit Logging -- ATR-01

The system **MUST** maintain a complete, tamper-evident audit trail for every interaction session. Required fields must be present and non-null.

2.4 Conformance Test Suite (CTS)

Five deterministic pass/fail tests. These are machine-readable (defined in `tests/nhid_conformance_test_suite_v1.yaml`):

Test ID	Name	What It Tests
IDG-01	Identity Disclosure Gate	AI identifies itself before any data exchange
PDX-01	Pre-Data Exchange Gate	No PHI requested before disclosure is confirmed
DBC-01	Deceptive Behavior Check	No deceptive audio artifacts present
EIT-01	Escalation Implementation Test	Functional human escalation path exists
ATR-01	Audit Trail Requirements	All required audit fields present and non-null

Additional test categories: EDGE cases (empty speech, null bytes, missing CallSid), BOT-TO-BOT detection.

2.4.1 -- Formal Measurement Definition

Impersonation Latency (IL), time form.

$$IL = t_{\{disclosure\}} - t_{\{connect\}}$$

where $t_{\{disclosure\}}$ is the first valid IDG-01 identity disclosure event ($disclosure_timestamp$) and $t_{\{connect\}}$ is the session start timestamp. If no valid disclosure occurs, IL is right-censored at call end and reported as:

$$IL \geq t_{\{call_end\}} - t_{\{connect\}}$$

Turn form.

$$IL_{\{turns\}} = \{ \text{completed turns before first valid disclosure} \}$$

Disclosure in the first message yields $IL_{\{turns\}} = 0$ -- the conformant target.

Pre-Disclosure PHI Exposure.

$$E_{\{PHI\}} = \{ f \text{ in } phi_accessed : t(f) < t_{\{disclosure\}} \}$$

PDX-01 fires when $E_{\{PHI\}} > 0$.

Plain language: IL measures how many seconds (or turns) passed before the AI said who it was. Zero is the target. PHI Exposure counts any data fields accessed before that disclosure -- even one triggers a PDX-01 violation.

2.5 Certification Tiers

Tier	Name	Price/ mo	Daily Limit	Voice Webhooks	Key Features
Free	Free	\$0	100 req/ day	Simulated only	Audit trail, basic proof, simulated voice
L1	NHID L1 -- Baseline	\$99	10,000 req	Simulated only	+ Replay, policy engine, API access
L2	NHID L2 -- Operational	\$499	100,000 req	Live (Retell, Vapi, Twilio)	+ SSO-ready, priority support
L3	NHID L3 -- Enterprise	\$2,500	Unlimited	Live	+ SSO, enterprise SLA, dedicated support

Source: `nhid-clinical/saas_layer/billing.py`

2.6 Specification Version History

Version	Key Changes
v1.0	Initial release with temporal disclosure requirements, NIST/HIPAA alignment mapping
v1.1	Shifted from "3-second window" to "Pre-Data Exchange gate"; added Known Gaps; refined positioning
v1.2	Bot-to-Bot Interaction Workflow; IVR Interruption; Escalation Transfer Tiers (Warm/Cold); SIP header identity
v1.3	Conformance Test Suite; L1/L2/L3 Certification Framework; Registry Architecture design; RFC 2119 terminology
v1.4 (planned)	Live Registry; Multilingual; Payer-initiated outbound; Technical Implementation Bindings; Pilot Certification

2.7 Document Layers

NHID-Clinical v1.3 has three distinct layers:

Layer 1 -- Normative Requirements: Enforceable rules using MUST/MUST NOT. Required for claiming NHID-Clinical conformance.

Layer 2 -- Recommended Practices: SHOULD/MAY guidance. Implementation flexibility while maintaining intent.

Layer 3 -- Informative/Future Scope: Non-normative. FHIR Technical Mapping, Badge Schema, NHID-Auth v1.0, Registry Architecture, JWT implementation.

2.8 What NHID-Clinical Is and Is Not

IS	IS NOT
A voluntary governance standard with binary, testable requirements	A replacement for HIPAA, GDPR, or other legal requirements

IS	IS NOT
Operational logic gates QA teams can implement	An "ethical AI" philosophy paper
Designed from real payer-side enforcement experience	A legal mandate
Informed by 8 months enforcing HIPAA compliance in payer operations	A certified accredited standard (it is a voluntary proposal)

3. Governance Architecture

3.1 Plain Language Summary

What is this? The set of rules, gates, and checks that make sure AI voice agents behave correctly in every call. Think of it as a bouncer at every stage of a call.

Why does it matter? Healthcare calls involve protected data. If an AI behaves badly -- delays disclosure, uses fake sounds, refuses to transfer -- there's real harm. Governance architecture makes that impossible to miss and easy to audit.

3.2 Governance Model

NHID-Clinical uses a **layered enforcement model**:

[Call Arrives]

[IDG-01 Gate] Has AI disclosed identity? NO -> DISCLOSE_IDENTITY action
YES

[PDX-01 Gate] Is PHI being requested? YES + no disclosure -> DENY_DATA

[DBC-01 Gate] Deceptive artifacts present? YES -> LOG_ONLY + flag

[EIT-01 Gate] Escalation requested? YES + no path -> ESCALATION_FAILED

[ATR-01 Gate] All audit fields present? NO -> LOG_ONLY + violation

[CONTINUE_AI] All gates passed

Priority order for composite decisions (higher number = takes precedence):

- DENY_DATA: 5
- ESCALATE_HUMAN: 4
- DISCLOSE_IDENTITY: 3
- LOG_ONLY: 2
- CONTINUE_AI: 1

Source: `nhid-clinical/src/nhid_policy_engine_v1.py:569-615`

3.3 Policy Layers

Layer 1 -- NHID Core Policy Engine (Read-Only)

- Pure Python, no I/O, no network calls, fully deterministic
- Implements IDG-01, PDX-01, DBC-01, EIT-01, ATR-01, and Bot-to-Bot supplemental rule
- Never raises exceptions; every code path returns a `PolicyDecision`
- Files: `nhid-clinical/src/nhid_policy_engine_v1.py`

Layer 2 -- SaaS Voice Policy Engine

- Real-time enforcement against live transcript chunks
- Rule-based: per-org rulesets stored in PostgreSQL
- Supports REQUIRE_UPFRONT_DISCLOSURE, HUMAN_ESCALATION_REQUESTED,

REQUIRE_AGENT_AUTHORIZATION, PROHIBIT_DECEPTIVE_ARTIFACTS

- Files: `nhid-clinical/saas_layer/voice_policy.py` , `nhid-clinical/saas_layer/voice_policy_store.py`

Layer 3 -- SaaS Gateway Enforcement

- Subscription gate (402 if not active)
 - Rate limiting (per-plan daily caps)
 - Admin session isolation
 - Files: `nhid-clinical/saas_layer/gateway.py`
-

3.4 Approval Workflows

Subscription Gate (`subscription_gated_org`):

- Blocks any org with `status != 'active'` -- HTTP 402 Payment Required
- Admin routes bypass this; they use `require_admin_session`

Voice Webhook Plan Gate (`plan_allows_voice_webhook`):

- Live voice webhook integrations (Retell, Vapi, Twilio) require L2 or higher
- Free and L1 orgs receive HTTP 403 with upgrade instruction

Rate Limiting (`check_rate_limit`):

- Free: 100 req/day, 10 RPM
 - L1: 10,000 req/day, 100 RPM
 - L2: 100,000 req/day, 500 RPM
 - L3: Unlimited, 2,000 RPM
-

3.5 Oversight Mechanisms

Tamper-Evident Audit Chain:

- HMAC-SHA256 signature on every event
- SHA256 hash chaining (each event hash includes the previous hash)
- Genesis hash: 64 zeros for first event in chain
- Append-only enforced at database level via Postgres triggers
- `pg_advisory_xact_lock(hashtext(org_id))` prevents concurrent write races

Audit Chain Verification:

- `GET /saas/audit/verify/{session_id}` -- full cryptographic re-derivation
- Constant-time comparison via `hmac.compare_digest`
- Rate-limited: 10 calls per org per 60 seconds
- Returns: `chain_valid`, `hmac_valid`, `event_count`, `breaks[]`

Source: `nhid-clinical/saas_layer/audit.py`

3.6 Human-in-the-Loop Controls

EIT-01 -- Mandatory Escalation:

- Any phrase matching escalation triggers -> `ESCALATE_HUMAN` action
- If no escalation path available -> `ESCALATION_FAILED` state + TwiML fallback
- Escalation state written to `voice_sessions` table in PostgreSQL

Admin Override:

- Admin can extend voice session TTL via `POST /admin/voice/sessions/{id}/extend`
 - Admin can force-delete a session via `DELETE /admin/voice/sessions/{id}`
 - Admin can view all escalated sessions via `GET /admin/voice/sessions?escalated_only=true`
-

3.7 Escalation Paths

Type A (Warm Transfer): Human staff available -> immediate transfer with context preservation.

Type B (Cold Transfer/After-Hours): Human staff unavailable -> state hours of operation + offer callback/voicemail.

MUST NOT: Infinite "I didn't understand" loops; sudden disconnection; forcing callers to restart.

3.8 Auditability

Every event appended to the audit chain includes:

- `event_id` (UUID)
- `session_id`
- `org_id`
- `seq_num` (sequential, per org)
- `event_type`, `state_before`, `state_after`

- `policy_action` , `reason_code` , `policy_version`
- `timestamp` (UTC ISO 8601)
- `prev_hash` , `event_hash` , `hmac_signature`

The Postgres `enforce_audit_append_only()` trigger blocks any UPDATE or DELETE on `audit_traces` . This is enforced at the database level, not just the application level.

4. Identity & Trust Infrastructure

4.1 Plain Language Summary

What is this? The system that proves who (or what) is in a call, whether they have permission to be there, and whether those credentials can be trusted.

Why does it matter? An AI can claim "I'm calling on behalf of Dr. Smith's office, NPI 1234567890" -- but without verification, that claim is worthless. Identity infrastructure is what makes the claim checkable.

4.2 Authentication (SaaS Layer)

Org API Key Authentication:

- Header: `X-API-Key`
- Required for all `/saas/*` routes except `/health` , `/saas/health` , billing webhook, and badge endpoint
- `validate_api_key()` checks key against `orgs` table, verifies `active = TRUE`
- Returns full org dict or `None`

Voice Webhook Authentication:

- Query parameter: `?api_key=<key>` (in webhook URL pasted to Retell/Vapi/Twilio dashboard)
- Same validation as header auth

Admin Session Authentication:

- Header: `X-Admin-Session`
- Session token (UUID) issued on `POST /admin/login` with username/password
- TTL: 8 hours (`_ADMIN_SESSION_TTL = 8 * 3600`)

- Stored in `admin_sessions` table in PostgreSQL
- Credentials: `ADMIN_USER` env var (default: `admin`), `ADMIN_PASS` env var (default: `nhidclinical1626`)

Source: `nhid-clinical/saas_layer/auth.py`, `nhid-clinical/saas_layer/gateway.py`

4.3 Cryptographic Agent Identity (NHID-Auth Layer)

Implemented in `nhid-clinical/src/agent_identity.py` as a v1.4 preview:

Ed25519 Key System:

- Each agent has an Ed25519 keypair (provider-issued)
- `AgentIdentityManager.generate_agent_keys()` -> (`Ed25519PrivateKey`, `Ed25519PublicKey`)
- Public keys stored as base64-encoded raw bytes

Delegation Chain:

```
Provider (NPI holder)

    signs Delegation(agent_id, public_key, scope, expires_at)

AgentPassport(delegation, provider_signature, agent_signature)
```

Delegation Fields:

- `provider_npi` -- NPI of authorizing provider
- `agent_id` -- stable agent identifier
- `agent_public_key_b64` -- base64 Ed25519 public key
- `scope` -- list of permitted operations
- `expires_at` -- Unix timestamp TTL
- `delegation_id` -- `del_{agent_id}_{timestamp}`

Verification (`verify_passport`):

1. Check revocation list
2. Check expiry
3. Verify provider signature over delegation JSON
4. Verify agent's own signature over delegation JSON
5. Return `VerificationResult(valid, reason, delegation_id, provider_npi, agent_id, scope)`

Revocation:

- `revoke_agent(agent_id)` adds to in-memory `revocation_list` with timestamp
- [Open Question: persistent revocation storage not yet implemented]

Source: `nhid-clinical/src/agent_identity.py`

4.4 Trust Scoring

[Missing: No formal trust scoring system is implemented in v1.3. The certification tier (L1/L2/L3) functions as a coarse trust signal. A live registry for real-time trust lookup is planned for v1.4+.]

4.5 Compliance Badge System

Public SVG badges signal NHID compliance to third parties:

- Endpoint: `GET /saas/badge/{org_id}` (public, no auth)
- Only active paid-tier orgs (L1/L2/L3) receive badges; free/inactive return 404
- Badge goes dark automatically when subscription lapses
- Visual design: dark background (#1e293b -> #0f172a gradient), tier-specific accent colors:
 - L1: teal `#00c2a8`
 - L2: blue `#38bdf8`
 - L3: purple `#c084fc`
- Badge embeds org name, tier level, "L{n} VERIFIED"
- Unique SVG IDs prevent conflicts when multiple badges appear on one page

Source: `nhid-clinical/saas_layer/gateway.py:557-650`

4.6 Org Identity & Role Management

Org Structure:

```

orgs (
  org_id          TEXT PRIMARY KEY,
  org_name        TEXT NOT NULL,
  api_key         TEXT NOT NULL UNIQUE,
  plan            TEXT NOT NULL DEFAULT 'free',
  status          TEXT NOT NULL DEFAULT 'active',
  stripe_customer_id TEXT,
  stripe_subscription_id TEXT,
  created_at      TEXT NOT NULL,
  usage_count     INTEGER NOT NULL DEFAULT 0,
  active          BOOLEAN NOT NULL DEFAULT TRUE,
  replit_user_id  TEXT,
  voice_session_ttl_hours INTEGER -- NULL = use server default (24h)
)

```

Self-Service Registration:

- `POST /saas/orgs/register` -- no admin required
- Creates free-tier org immediately
- Name: 2-120 characters
- Returns `org_id`, `org_name`, `api_key`, `plan`

User Linkage:

- `POST /saas/org/link` -- associates Replit user ID with org (idempotent)
- `GET /saas/org/by-user/{replit_user_id}` -- auto-restore session on login

5. Healthcare AI Agent Verification

5.1 Plain Language Summary

What is this? The specific checks that happen during a live healthcare AI call to make sure the AI is behaving correctly -- disclosing, not deceiving, escalating when asked, and logging everything.

Who uses it? Engineering teams integrating with the SaaS gateway; compliance teams reviewing audit trails.

5.2 Agent Validation (Five Conformance Controls)

IDG-01 -- Identity Disclosure Gate

```
# Pass condition
disclosure_timestamp is not None AND identity_assertion_text.strip() != ""
# Fail condition
disclosure_timestamp is None # -> PolicyAction.DISCLOSE_IDENTITY
identity_assertion_text == "" # -> PolicyAction.CONTINUE_AI + MAJOR violation
```

Twiml fallback on failure:

"Hello. I am an automated system. I am not a human representative. How can I help you today?"

PDX-01 -- Pre-Data Exchange Gate

PHI trigger fields: `member_id`, `npi`, `date_of_birth`, `claim_number`, `prior_auth_number`, `diagnosis_code`, `procedure_code`, `provider_tin`

PHI speech patterns: "member id", "member number", "date of birth", "dob", "claim number", "authorization number", "prior auth", "npi number", "tax id", "tin ", "diagnosis", "procedure code", "icd"

```
# Fail condition
disclosure_timestamp is None AND (phi_in_speech OR phi_in_fields)
# -> PolicyAction.DENY_DATA, reason_code="PDX01_PHI_GATE_TRIGGERED"
```

DBC-01 -- Deceptive Behavior Check

Prohibited artifacts: `fake_breathing`, `fake_typing`, `artificial_pause`, `human_name_claim`, `license_claim`, `employer_claim_unverified`

Prohibited transcript markers: `[breathing]`, `[typing]`, `[sigh]`, `[keyboard]`

Detection also fires if `session_state["human_name_used"]` AND NOT `session_state["ai_qualifier_present"]`

```
# Fail condition: any deceptive_artifact_flags present
# -> PolicyAction.LOG_ONLY, reason_code="DBC01_ARTIFACT_DETECTED"
# Note: LOG_ONLY (not DENY_DATA) -- the call continues but the violation is recorded
```

EIT-01 -- Escalation Implementation Test

Escalation trigger phrases: "speak to a human", "talk to a person", "representative", "transfer me", "speak to someone", "real person", "human agent", "supervisor", "manager", "i need help", "can't help me", "not what i asked"

```
# If escalation requested AND path unavailable
# -> PolicyAction.ESCALATE_HUMAN, reason_code="EIT01_NO_ESCALATION_PATH"
# If escalation requested AND path available
# -> PolicyAction.ESCALATE_HUMAN, reason_code="EIT01_ESCALATION_TRIGGERED"
```

ATR-01 -- Audit Trail Requirements

Required fields: `event_id`, `timestamp`, `session_id`, `request_id`, `event_type`, `actor_id`, `state_before`, `state_after`, `replay_mode`, `external_calls_cached`, `execution_context`

Required `execution_context` fields: `pipeline_version`, `policy_engine_version`, `nhid_schema_version`

5.3 Bot-to-Bot Supplemental Rule

When `counterparty_type == "ai_agent"`, stricter disclosure and verification gates apply:

```
# Both parties must be disclosed as non-human before any data exchange
# If disclosure_timestamp is None in bot-to-bot context:
# -> PolicyAction.DENY_DATA, reason_code="BOT2BOT_UNDISCLOSED_AGENT"
```

This rule is additive -- it does NOT replace IDG-01 or PDX-01.

Source: `nhid-clinical/src/nhid_policy_engine_v1.py:506-562`

5.4 Voice Session State Machine

States in the voice session lifecycle:

State	Meaning
<code>idle</code>	Session not yet started
<code>active</code>	Call in progress
<code>AWAITING_DISCLOSURE</code>	Pre-disclosure
<code>DISCLOSED</code>	AI identity confirmed
<code>DATA_EXCHANGE_AUTHORIZED</code>	PHI gate cleared
<code>GATE_BLOCKED</code>	PHI blocked -- disclosure required first

State	Meaning
DECEPTION_FLAGGED	DBC-01 violation detected
ESCALATING	Transfer to human in progress
ESCALATION_FAILED	Transfer requested but no path available
ERROR	Internal policy engine error
escalated	PostgreSQL session flag set

Session persistence: PostgreSQL `voice_sessions` table with `SELECT FOR UPDATE` for transactional read-modify-write.

5.5 Verification Workflows

Incoming Call:

1. `POST /saas/voice/webhook/incoming?api_key=<key>` (or `/saas/voice/incoming` with header auth)
2. Provider auto-detected (Retell / Vapi / Twilio / Generic)
3. Session created in `voice_sessions` table
4. `voice_session_start` event appended to audit chain
5. Returns `disclosure_text`: *"This call is handled by an AI system operating on behalf of {org_name}. You may request a human agent at any time."*

Transcript Processing:

1. `POST /saas/voice/webhook/transcript?api_key=<key>`
2. Session locked via `SELECT FOR UPDATE`
3. Org policy loaded from `voice_policy_configs`
4. `run_voice_policy()` evaluates transcript against ruleset
5. Decision (allow/disclose/escalate/deny) appended to audit chain with HMAC signature
6. Session state updated atomically in same transaction
7. Returns: `action`, `reason_code`, `session_id`, `event_hash`

5.6 Monitoring & Fallback

Voice Session TTL Cleanup:

- Background coroutine `_voice_session_cleanup_loop()` runs every 6 hours (configurable via `VOICE_SESSION_PURGE_INTERVAL_SECS`)

- Default TTL: 24 hours (configurable via `VOICE_SESSION_TTL_HOURS`)
- Per-org TTL override via `voice_session_ttl_hours` on `orgs` table
- Valid TTL values: 4h, 24h, 72h, 168h (7 days)

Audit Write Failure Handling:

- If `audit_svc.append_trace()` fails, the entire request returns HTTP 500
- Hard failure by design: callers must know the tamper-evident record was not created
- Voice session is deleted on startup audit failure (rollback)

5.7 Failure Traces (Pre-Generated)

Ten pre-generated failure traces documenting specific governance failure modes (in `nhid-clinical/traces/`):

Trace	Failure Mode
trace-01	Empty speech not validated; disclosure gate bypassed
trace-02	Null byte injection through sanitization
trace-03	No CallSid -> session binding failure
trace-04	PHI exchanged before disclosure (IDG-01 + PDX-01)
trace-05	No human transfer available (EIT-01)
trace-06	Synthetic breathing/typing detected (DBC-01)
trace-07	Missing audit trail field (ATR-01)
trace-08	AI-to-AI calls bypass identity gates
trace-09	Non-deterministic replay divergence
trace-10	Incomplete state boundary transition

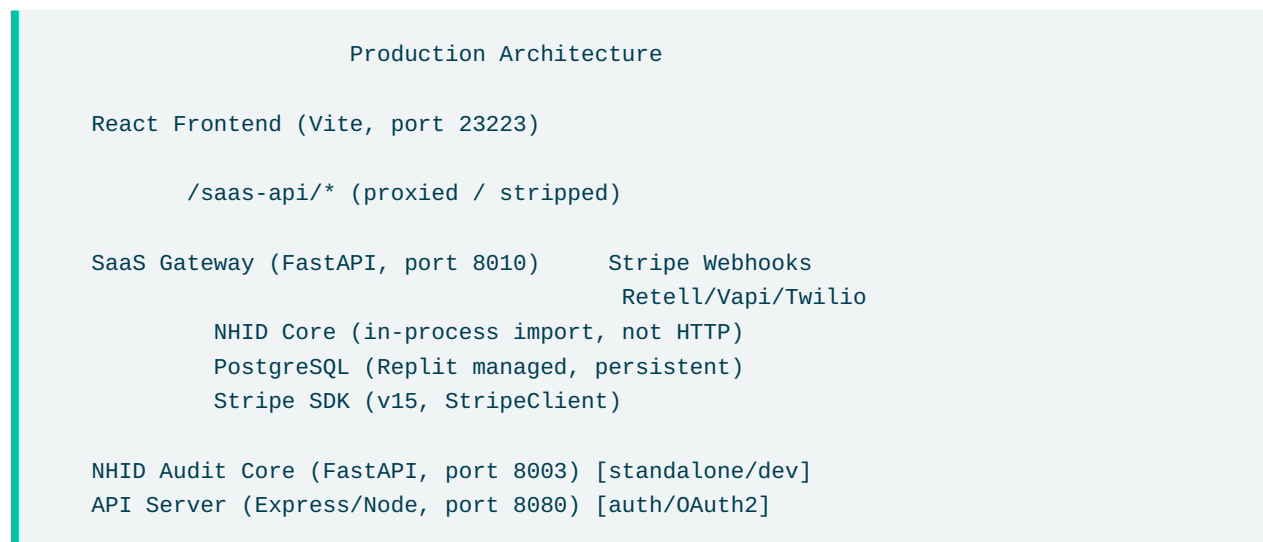
6. Technical Architecture

6.1 Plain Language Summary

What is this? The full technical stack -- every service, database, and interface that makes NHID-Clinical SaaS run.

Why does it matter? Engineers need to know how everything connects to build on, maintain, or audit the system.

6.2 Service Map



Key architectural invariant: The SaaS Gateway accesses NHID core via direct Python imports (via `nhid_client.py`), NOT via HTTP to port 8000. The Bridge service (port 8001) is a legacy artifact, no longer required in production.

6.3 Port Assignments (Fixed)

Port	Service	Notes
8000	NHID Clinical Core (app.py)	Test/clinical target only
8001	NHID Clinical Bridge (replit_backend_bridge)	Legacy, not needed in production
8003	NHID Audit Core (FastAPI)	Standalone audit service

Port	Service	Notes
8010	NHID Clinical SaaS Gateway (saas_main.py)	Production entry point
5174/5175	NHID Clinical Viewer (Vite)	Dev tool
8080	API Server (Node/Express)	OAuth2/OIDC auth
23223	nhid-saas frontend (Vite)	React SaaS dashboard

Port 8000 was freed from the Audit Core (moved to 8003) specifically so the NHID Clinical test suite can keep pointing at 8000 without reconfiguration.

Source: `.agents/memory/port-assignments.md`

6.4 Frontend

Stack: React 19 + Vite 7 + Radix UI + TanStack Query + Recharts + Sonner toasts + Wouter router

Design System (Canonical):

- Background: `#070c17` (deep dark)
- Primary/Teal: `#00c2a8`
- Accent/Cyan: `#53d8fb`
- Font: Raleway
- Style: Glassmorphism (glass-effect cards)
- Dark class forced via `useEffect` in `App.tsx`

Pages:

- `/` (onboarding) -- `src/pages/onboarding.tsx`
- `/dashboard` -- `src/pages/dashboard.tsx` (GlassCard design system)
- `/usage` -- `src/pages/usage.tsx`
- `/billing` -- `src/pages/billing.tsx` (Stripe checkout)
- `/audit` -- `src/pages/audit.tsx` (audit trail viewer)
- `/admin` -- `src/pages/admin.tsx`
- `/try` -- `src/pages/try.tsx` (demo)
- `/proof` -- `src/pages/proof.tsx`
- `/trace` -- `src/pages/trace.tsx`
- `/docs-sdk` -- `src/pages/docs-sdk.tsx`

Important bug fix documented:

`proof.trace` is `{ events: [...] }` not a flat array. Access via `(proof.trace as any)?.events`, not `Array.isArray(proof.trace)`.

Source: `artifacts/nhid-saas/`, `.agents/memory/nhid-proof-events.md`

6.5 Backend -- SaaS Gateway

Stack: Python 3.11+ / FastAPI / Uvicorn / psycpg2 / Stripe Python SDK v15

Entry point: `nhid-clinical/saas_main.py` -> runs on `$PORT` (default 8010)

Key modules in `nhid-clinical/saas_layer/` :

File	Purpose
<code>gateway.py</code>	FastAPI app, all routes, middleware, startup lifecycle
<code>auth.py</code>	Org management, API key validation, admin sessions, DB schema bootstrap
<code>billing.py</code>	Plan definitions, rate limiting, upgrade paths
<code>audit.py</code>	HMAC-SHA256 tamper-evidence, hash chaining, chain verification
<code>stripe_billing.py</code>	Stripe checkout, webhook handling, subscription mapping
<code>stripe_client.py</code>	StripeClient initialization (v15 SDK)
<code>usage.py</code>	Usage log tracking, daily/monthly aggregation, global stats
<code>voice_policy.py</code>	Real-time rule-based policy enforcement
<code>voice_policy_store.py</code>	Per-org ruleset persistence, built-in rule registry
<code>voice_sessions.py</code>	PostgreSQL-backed voice session state
<code>nhid_client.py</code>	Direct Python import wrapper over <code>nhid_event_store</code>
<code>db.py</code>	Single PostgreSQL connection factory (<code>get_conn</code>)

CORS: `allow_origins=["*"]` -- [Needs Review: overly permissive for production]

Path prefix stripping middleware: `/saas-api` prefix stripped before routing (handles Replit production proxy).

6.6 Backend -- NHID Core (Read-Only)

Stack: Python / FastAPI (app.py) / SQLite (nhid_event_store)

Files (read-only, must not be modified except 2 allowed patches):

- `app.py` -- Twilio TwiML endpoints (`/voice/incoming` , `/voice/process`)
- `nhid_engine.py` -- Pure state machine (VALID_STATES, VALID_TRANSITIONS)
- `nhid_policy.py` -- Policy decision enums
- `nhid_event_store.py` -- SQLite event persistence, deduplication, idempotency
- `llm.py` -- LLM integration stub
- `twilio_helper.py` -- Twilio TwiML helpers

Two allowed targeted patches:

1. CallSid validation
2. GET/POST replay

Why read-only: nhid-clinical is a cloned external repo. Keeping core files untouched preserves the 43-test pass rate and clean separation.

6.7 Database

Primary: Replit PostgreSQL (persistent, managed)

- Canonical for all SaaS data (orgs, usage, audit, voice sessions, billing)
- Migrated from SQLite on 2026-05-29
- Connection via `psycopg2` , `RealDictCursor` , `%s` placeholders
- `get_conn()` in `saas_layer/db.py` is the single connection factory

Tables:

- `orgs` -- multi-tenant org registry
- `usage_log` -- per-request usage tracking
- `admin_sessions` -- admin session tokens with TTL
- `processed_events` -- Stripe webhook idempotency
- `audit_traces` -- tamper-evident event log (append-only triggers)
- `voice_sessions` -- real-time call state
- `voice_policy_configs` -- per-org policy rulesets (append-only versioning)

Append-only enforcement:

```
-- Postgres trigger function
CREATE FUNCTION enforce_audit_append_only() RETURNS trigger AS
```math
BEGIN RAISE EXCEPTION 'audit_traces is append-only'; END;
```

LANGUAGE plpgsql;

-- Two triggers: one for UPDATE, one for DELETE

**\*\*Fallback:\*\*** SQLite (`nhid\_event\_store` in nhid core) remains for core test suite only. Never re-introduce SQLite into saas\_layer.

**\*\*Source:\*\*** `.agents/memory/saas-postgres-migration.md`, `nhid-clinical/saas\_layer/auth.py`

---

### ### 6.8 APIs

**\*\*SaaS Gateway API Endpoints:\*\***

Method	Path	Auth	Description
GET	/health	None	System health check
GET	/saas/health	None	Alias for /health
GET	/saas/system/status	None	Full system snapshot
POST	/saas/orgs/register	None	Self-service org registration
GET	/saas/orgs/me	API Key	Org details + usage
POST	/saas/org/link	API Key	Link Replit user to org
GET	/saas/org/by-user/{id}	None	Lookup org by Replit user
POST	/saas/billing/checkout	API Key	Create Stripe checkout session
POST	/saas/billing/webhook	None (Stripe sig)	Stripe webhook receiver
GET	/saas/billing/plans	None	List available plans
GET	/saas/billing/publishable-key	None	Stripe public key
GET	/saas/badge/{org_id}	None	SVG compliance badge
POST	/saas/trace	API Key (sub-gated)	Append audit event
GET	/saas/proof/{session_id}	API Key (sub-gated)	Get audit proof
GET	/saas/audit/verify/{session_id}	API Key (sub-gated)	Cryptographic verification
GET	/saas/audit/proof/{session_id}	API Key (sub-gated)	Enhanced audit proof
POST	/saas/voice/incoming	API Key	Register inbound call
POST	/saas/voice/transcript	API Key	Process transcript chunk
GET	/saas/voice/policy	API Key	Get org voice policy
PUT	/saas/voice/policy	API Key	Save org voice policy
POST	/saas/voice/webhook/incoming	?api_key=	Webhook: incoming call (L2+)
POST	/saas/voice/webhook/transcript	?api_key=	Webhook: transcript (L2+)
GET	/saas/usage	API Key	Usage summary
GET	/saas/usage/recent	API Key	Recent activity
GET	/saas/replay/{session_id}	API Key (sub-gated)	Replay session events
POST	/admin/login	Username/Password	Admin session
POST	/admin/logout	Admin Session	Invalidate session
GET	/admin/session	Admin Session	Validate session
GET	/admin/orgs	Admin Session	List all orgs with usage
POST	/saas/admin/orgs	Admin Session	Create org
GET	/saas/admin/orgs	Admin Session	List orgs
GET	/admin/usage	Admin Session	Global usage stats
GET	/admin/voice/sessions	Admin Session	List voice sessions

```
| POST | `/admin/voice/sessions/{id}/extend` | Admin Session | Extend TTL |
| DELETE | `/admin/voice/sessions/{id}` | Admin Session | Force-delete session |
| PATCH | `/admin/orgs/{id}/session-retention` | Admin Session | Set per-org TTL |
| GET | `/admin/org/{org_id}` | Admin Session | Single org detail |
```

---

### ### 6.9 Integrations

**\*\*Voice Provider Webhook Normalization:\*\***

The gateway auto-detects provider from payload shape:

```
| Provider | Detection Signal | Call ID Field |
|-----|-----|-----|
| Retell AI | `call_id` + `event` at top level | `call_id` |
| Vapi | `message.type` + `message.call.id` | `message.call.id` |
| Twilio | `CallSid` field | `CallSid` |
| Generic | fallback | `caller_id` or `session_id` |
```

**\*\*In-memory call ID map:\*\*** `\_call\_id\_map: Dict[str, str]` maps `provider\_call\_id` -> `session\_id`. Protected by `threading.Lock()`. Populated on incoming webhook; used to correlate transcript webhooks.

**\*\*Stripe Integration (v15 SDK):\*\***

Critical quirks (see `.agents/memory/stripe-python-v15.md`):

- Use `stripe.StripeClient(key)` NOT `stripe.Stripe`
- Use `client.v1.\*` namespace
- Params are dicts, not keyword args
- `metadata.to\_dict().get("key")` -- NOT `metadata.get("key")` (AttributeError)
- Webhook: `stripe.Webhook.construct\_event(payload, sig\_header, secret)` (module-level, still works in v15)

Handled Stripe events: `checkout.session.completed`, `invoice.paid`,  
`customer.subscription.deleted`, `customer.subscription.updated`

**\*\*Twilio Adapter (`nhid-clinical/adapters/twilio\_adapter.py`):\*\***

- Converts Twilio transcripts to NHID-Clinical v1.3 traces
- Detects: disclosure events, escalation events, data requests

---

### ### 6.10 Security

**\*\*Production Security Hardening (from `attached\_assets/Pasted-You-are-an-expert-security-engineer-\*`):\*\***

- No exposed admin endpoints without session token
- No debug routes in production

- No unprotected internal data leaks
- Stripe webhook signature validation enabled
- HMAC\_SECRET never logged, never included in responses
- `hmac.compare\_digest` for all HMAC comparisons (constant-time)
- `pg\_advisory\_xact\_lock` for concurrent write serialization
- Append-only DB triggers for audit integrity

**\*\*pnpm Supply-Chain Defense:\*\***

- 1440-minute (24-hour) release age gate on npm packages (`pnpm-workspace.yaml`)
- Prevents newly published (potentially compromised) packages from being installed

**\*\*Known Issues/TODOs:\*\***

- `allow\_origins=["\*"]` in CORS middleware -- [Needs Review: should be restricted to known frontend origins in production]
- HMAC\_SECRET default fallback raises RuntimeError cleanly at startup

---

### ### 6.11 Infrastructure & Deployment

**\*\*Platform:\*\*** Replit (managed hosting)

**\*\*Detection:\*\*** `\_is\_production()` checks `APP\_ENV=production` OR `REPLIT\_DEPLOYMENT=1`

**\*\*Required Environment Variables:\*\***

- `DATABASE\_URL` -- PostgreSQL connection string
- `HMAC\_SECRET` -- HMAC signing key (required; raises RuntimeError if missing)
- `STRIPE\_SECRET\_KEY` -- Stripe secret key (`sk\_test\_\*` or `sk\_live\_\*`)
- `STRIPE\_PUBLISHABLE\_KEY` -- Stripe public key
- `STRIPE\_WEBHOOK\_SECRET` -- Required in live mode
- `SAAS\_ADMIN\_KEY` -- Legacy admin key (default: `nhid-admin-key-dev`)
- `ADMIN\_USER` -- Admin username (default: `admin`)
- `ADMIN\_PASS` -- Admin password (default: `nhidclinical1626`)
- `PORT` -- SaaS gateway port (default: 8010)
- `VOICE\_SESSION\_TTL\_HOURS` -- Voice session TTL (default: 24)
- `VOICE\_SESSION\_PURGE\_INTERVAL\_SECS` -- Cleanup interval (default: 21600)

**\*\*GitHub Actions CI:\*\***

- `.github/workflows/jekyll-docker.yml`
- `.github/workflows/python-publish.yml`

---

### ### 6.12 NHID Core API (for reference)

Canonical Event Schema (`schema/nhid\_trace\_schema\_v1.json`, JSON Schema Draft 2020-12):

**\*\*Required fields:\*\***

```
`event_id` (UUID), `timestamp` (ISO 8601), `session_id`, `request_id`, `event_type`
(INGEST/VALIDATE/STATE/POLICY/EXEC/EVENT/PERSIST), `actor_id`, `counterparty_type`
(human_operator/ai_agent/ivr_system/unknown), `state_before`, `state_after`,
`partial_failure` (bool), `boundary_violations` (array), `replay_mode` (live/cached),
`external_calls_cached` (bool), `execution_context` (object with pipeline_version,
policy_engine_version, nhid_schema_version)
```

```
Constraint: when `replay_mode` = "cached", `external_calls_cached` MUST be `true`.
```

```

```

## ## 7. Implementation Roadmap

### ### 7.1 Current State (as of 2026-06-12)

```
Completed:
```

- NHID-Clinical v1.3 open proposal published (CC BY 4.0)
- Policy engine v1.0.0 implemented (pure Python, fully deterministic)
- Conformance test suite (18 YAML test cases)
- Failure trace generator (10 pre-built traces)
- NHID-Clinical SaaS Gateway (FastAPI, port 8010)
- Multi-tenant auth (API key + admin session)
- Stripe billing integration (checkout, webhooks, plan gating)
- HMAC-SHA256 tamper-evident audit chain
- PostgreSQL migration (from SQLite, 2026-05-29)
- Append-only audit triggers in Postgres
- Voice session management (PostgreSQL-backed)
- Real-time voice policy enforcement
- Per-org configurable rulesets
- Voice webhook normalization (Retell, Vapi, Twilio)
- Compliance badge system (SVG, per-org)
- React SaaS frontend (dark glassmorphism design)
- Ed25519 agent identity system (v1.4 preview)
- Twilio adapter

```
Remaining for Production Launch (from finalization document):
```

- Verify 43/0/0 NHID test suite unchanged
- Confirm Stripe live mode (sk\_live\_ keys)
- Register Stripe webhook endpoint in dashboard
- Confirm STRIPE\_WEBHOOK\_SECRET configured
- Verify no localhost:8001 references anywhere
- React frontend: no debug UI, no dev logs, no placeholders
- CORS restriction (replace `allow\_origins=["\*"]`)

```

```

### ### 7.2 v1.4 Roadmap (Planned)

```
| Feature | Priority | Target |
```

Live Registry Launch	High	Q1-Q2 2027
Outbound Call Guidance (Payer-initiated)	High	Q1-Q2 2027
Multilingual Support	Medium	Q1-Q2 2027
Technical Implementation Bindings (OpenTelemetry, OPA/Cedar)	Medium	Q1-Q2 2027
Pilot Certification Program (first L1/L2 vendors)	Low	Q1-Q2 2027
Persistent agent revocation storage	[Open Question]	TBD
B2C/patient-facing workflow coverage	Future major version	Post-v1.4

---

### ### 7.3 Public vs. Private Repo Split

```

PUBLIC (`NHID-Clinical` repo, open standard):
- Pure policy engine (`voice_policy.py` -- imports only `typing`)
- Pure unit tests (TestCheckDisclosure, TestCheckEscalation, TestRunVoicePolicy,
TestRulesetPolicyEngine)

PRIVATE (`NHID-Clinical-SaaS` repo):
- FastAPI gateway, PostgreSQL, billing, telephony
- TestVoiceWebhookPlanGate (L2+ monetization gate)
- Integration tests (TestVoiceIncoming, TestVoiceTranscript)

Rationale: Open-standard credibility lives in deterministic policy rules.
Monetization lives in the hosted implementation. Publishing the engine strengthens the
standard without giving away the paid product.

Source: `.agents/memory/public-reference-split.md`

```

---

## ## 8. Coding & Development

### ### 8.1 Repository Structure

```

NHID-Clinical-SaaS/
nhid-clinical/ # Cloned open proposal (mostly read-only)
app.py # FastAPI Twilio endpoints (READ-ONLY)
nhid_engine.py # State machine (READ-ONLY)
nhid_policy.py # Policy enums (READ-ONLY)
nhid_event_store.py # SQLite persistence (READ-ONLY)
src/
nhid_policy_engine_v1.py # Core policy (READ-ONLY)
agent_identity.py # Ed25519 identity (READ-ONLY)
schema/nhid_trace_schema_v1.json
tests/ # Conformance suite (READ-ONLY)

```

traces/ # 10 failure traces  
adapters/twilio\_adapter.py  
saas\_layer/ # SaaS additions (WRITABLE)  
gateway.py # Main FastAPI app  
auth.py # Org/key management  
billing.py # Plan definitions  
audit.py # HMAC chain  
stripe\_billing.py # Stripe integration  
voice\_policy.py # Real-time enforcement  
voice\_policy\_store.py  
voice\_sessions.py  
nhid\_client.py # Core import wrapper  
db.py # PostgreSQL connection  
saas\_main.py # SaaS gateway entrypoint  
replit\_backend\_bridge.py # Legacy bridge (not needed in prod)  
artifacts/  
nhid-saas/ # React frontend  
api-server/ # Express/Node auth server  
nhid-audit-core/ # Standalone audit service  
mockup-sandbox/ # UI component showcase  
lib/  
db/ # Drizzle ORM schema  
api-spec/ # OpenAPI spec  
api-zod/ # Zod validators  
api-client-react/ # React API client  
replit-auth-web/ # useAuth hook  
scripts/ # Build utilities  
.agents/memory/ # Agent-readable architectural decisions  
attached\_assets/ # Session context captures  
package.json # pnpm workspace  
pyproject.toml # Python 3.11+  
pnpm-workspace.yaml # Supply-chain security config

```

8.2 Coding Standards

Python:
- Python 3.11+
- `from __future__ import annotations` in all policy engine files
- Pure functions only in policy engine -- no I/O, no LLM calls, no network
- Every function returns a `PolicyDecision` -- never raises
- `dataclass(frozen=True)` for immutable value objects (BoundaryViolation)
- All policy functions wrapped in try/except -> `_internal_error_decision()`
- SQLite: `?` placeholders; PostgreSQL: `%s` placeholders (never mix)
- `with conn:` context manager for transactions; `conn.close()` in `finally`
- `BOOLEAN` in Postgres (not integer 0/1)
- `INSERT ... ON CONFLICT DO NOTHING` (not `INSERT OR IGNORE`)

TypeScript:
- ES2022 target, strict mode
- Wouter for routing (not React Router)
- TanStack Query for server state
- Radix UI primitives for components
- Zod for validation (auto-generated from OpenAPI spec)

Naming:
- NHID rule IDs: `IDG-01`, `PDX-01`, `DBC-01`, `EIT-01`, `ATR-01`
- Policy actions: `DISCLOSE_IDENTITY`, `ESCALATE_HUMAN`, `CONTINUE_AI`, `DENY_DATA`, `LOG_ONLY`
- Reason codes: `IDG01_DISCLOSURE_CONFIRMED`, `PDX01_PHI_GATE_TRIGGERED`, etc.

8.3 Development Workflow

Start all services:

```bash
# NHID Clinical Core (port 8000)
cd nhid-clinical && python app.py

# NHID Clinical Bridge (port 8001) -- legacy, not needed in prod
cd nhid-clinical && python -m uvicorn replit_backend_bridge:app --host 0.0.0.0 --port 8001 --reload

# NHID SaaS Gateway (port 8010)
cd nhid-clinical && PORT=8010 python saas_main.py

# NHID Audit Core (port 8003)
cd artifacts/nhid-audit-core && python -m uvicorn main:app --host 0.0.0.0 --port 8003 --reload

```

```
# API Server (port 8080)
pnpm run build && cd artifacts/api-server && pnpm run dev

# Frontend (port 23223)
cd artifacts/nhid-saas && pnpm run dev
```

Run tests:

```
cd nhid-clinical
python -m pytest tests/ -v
# Expected: 25 passed, 18 skipped
# 18 skipped = integration tests requiring live server at http://127.0.0.1:8000

# Generate failure traces (offline)
python tests/trace_generator.py --offline

# Run Twilio adapter demo
python adapters/twilio_adapter.py
```

8.4 Branching Strategy

Active development branch: `claude/nhid-clinical-master-archive-dfbt5d`

[Open Question: Full git branching strategy not explicitly documented. `main` is the production target. Feature branches are used per session.]

8.5 Key Constraints (Non-Negotiable)

From `.agents/memory/nhid-core-constraint.md`:

The following files in `nhid-clinical/` MUST NOT be modified:

`app.py` (exception: two targeted patches), `nhid_engine.py`, `nhid_policy.py`,
`nhid_event_store.py`, `tests/`, `src/`, `schema/`, `pytest.ini`, `requirements.txt`,
`twilio_helper.py`, `llm.py`

From production launch requirements:

- NHID Core tests MUST remain 43/0/0
 - NO reintroduction of Bridge service or HTTP dependency to internal core
 - SaaS Gateway is the ONLY backend control plane
 - All production logic must live in SaaS layer only
-

8.6 Stripe SDK Implementation Notes

From `.agents/memory/stripe-python-v15.md` :

```
# CORRECT
from saas_layer.stripe_client import get_stripe_client
client = get_stripe_client() # Fresh each time, never cache
prices = client.v1.prices.list({"active": True})
session = client.v1.checkout.sessions.create({
    "customer": customer_id,
    "mode": "subscription",
    "line_items": [{"price": price_id, "quantity": 1}],
    "success_url": success_url,
    "cancel_url": cancel_url,
})
# Metadata access -- CRITICAL
org_id = subscription.metadata.to_dict().get("org_id") # CORRECT
# NOT: subscription.metadata.get("org_id") # AttributeError
# NOT: dict(subscription.metadata)          # KeyError

# Webhook parsing
event = stripe.Webhook.construct_event(payload, sig_header, secret) # OK in v15
# NOT: stripe.Event.construct_from(...) # May not exist
```

8.7 Audit Concurrency Fix

From `.agents/memory/audit-chain-concurrency.md` :

```
# CORRECT: Advisory lock serializes first-insert races
cur.execute("SELECT pg_advisory_xact_lock(hashtext(%s))", (org_id,))
cur.execute(
    "SELECT event_hash, seq_num FROM audit_traces "
    "WHERE org_id = %s ORDER BY seq_num DESC LIMIT 1",
    (org_id,),
)
# NOT: SELECT ... FOR UPDATE (fails on empty chains -- no rows to lock)
```

9. Claude Code, Manus, Perplexity, ChatGPT, Grok, Kimi, or Other LLM Tasking

9.1 Agent Roles

Claude Code (primary development agent):

- All implementation, architecture decisions, and code changes
- Reads `.agents/memory/` files at session start for constraint context
- Must respect read-only file constraints
- Must not modify NHID core test suite
- Must maintain 43/0/0 test pass rate

Perplexity / Web Research Agents:

- Research regulatory context (state bills, CMS, FCC rulings)
- Market data validation (Health Affairs, Peterson Health Technology Institute)
- Standards research (NIST AI RMF, ISO 42001, HL7 FHIR)

Manus / Task Automation:

[Missing: No documented use of Manus in source material]

9.2 Agent Memory System

The `.agents/memory/` directory contains constraint documents that agents read to maintain session continuity:

File	Purpose
<code>MEMORY.md</code>	Index of all constraint documents

File	Purpose
<code>nhid-core-constraint.md</code>	Read-only file list
<code>nhid-saas-isolation.md</code>	HTTP-only access via Bridge (legacy note)
<code>saas-layer.md</code>	SaaS gateway architecture
<code>port-assignments.md</code>	Fixed port map
<code>public-reference-split.md</code>	Public vs. private repo split rules
<code>saas-postgres-migration.md</code>	PostgreSQL migration rules
<code>audit-chain-concurrency.md</code>	Advisory lock requirement
<code>stripe-python-v15.md</code>	Stripe SDK quirks
<code>nhid-clinical-design.md</code>	Design system tokens
<code>nhid-proof-events.md</code>	proof.trace access bug fix

9.3 Prompt Patterns

When tasking an LLM to modify SaaS layer code:

"NHID Core (app.py, nhid_engine.py, nhid_policy.py, nhid_event_store.py, tests/, src/, schema/) is read-only. Only modify files in saas_layer/ or add new files alongside existing ones. Do not reintroduce SQLite in saas_layer. Use %s placeholders for PostgreSQL. All audit writes must go through saas_layer/audit.py::append_trace(). Do not introduce Bridge HTTP calls -- NHID core is accessed via direct Python import."

When tasking for policy engine changes:

"The policy engine in src/nhid_policy_engine_v1.py is pure: no I/O, no network, no randomness. Every function must return a PolicyDecision and never raise. Add new rule types via _RULE_EVALUATORS dict in voice_policy.py (saas_layer), not in the core engine."

When tasking for frontend changes:

"Use the canonical design system: #070c17 background, #00c2a8 teal, #53d8fb cyan, Raleway font, glassmorphism. Force `.dark` class via `useEffect` in `App.tsx`. Access `proof.trace` as `(proof.trace as any)?.events` -- it is an object with an events array, not a flat array."

9.4 Research Workflows

Regulatory research:

1. Check state bills (CA AB 489, CA AB 2905, NY S7263, Hawaii SB 2281, UT SB 226, TX TRAIGA)
2. Check FCC rulings (February 2024 declaratory ruling on non-human voice)
3. Check TCPA (47 U.S.C. § 227)
4. Map to NHID-Clinical control IDs in `healthcare_governance` schema

Market research:

1. Administrative cost data (Health Affairs, Peterson Health Technology Institute)
2. AI voice agent vendor landscape (Retell AI, Vapi, Twilio, Nuance/Microsoft)
3. Payer operations pain points

9.5 Governance Workflows for AI

The policy engine itself is a governance system for AI. Key design principles that should inform any AI agent operating within NHID-Clinical:

1. **Determinism over flexibility:** Policy decisions must be reproducible from identical inputs
 2. **Fail safe:** Internal errors -> `_internal_error_decision()` -> LOG_ONLY + CRITICAL ATR-01 violation
 3. **No silent failures:** Every error must produce an error object AND a `boundary_violation` entry
 4. **Audit first:** If `audit_svc.append_trace()` fails, the whole request fails (HTTP 500)
 5. **Never raise from policy:** All policy functions catch all exceptions internally
-

10. Website Content

10.1 Domain

Public standard: <https://nhid-clinical.org>

Source repo: <https://github.com/thankcheeses/NHID-Clinical>

Static pages served from: `nhid-clinical/` directory (index.html, about.html, faq.html, proof.html, simulator.html, specification.html, etc.)

10.2 Homepage Key Copy

Problem statement (verbatim from README/spec):

"Picture this: You're a customer service rep at an insurance company. A call comes in from what sounds like a provider office. They need claim status or eligibility information... 3-5 minutes in, something feels off. The cadence is too consistent. The pauses are too perfect. You ask: 'Am I speaking with a real person?' Silence. Then: 'I am a virtual assistant calling on behalf of Dr. Smith's Dental Office.'"

What this is:

"NHID-Clinical defines a minimum control baseline for non-human identity disclosure in B2B healthcare voice interactions."

The four requirements (plain language):

1. Identify as automated before asking for any data
2. No audio designed to sound human (fake breathing, filler, call center noise)
3. Immediate transfer to a human on request
4. Basic log: what happened and when

The "Green Lane" principle:

"When AI agents identify themselves upfront and follow the rules, everyone wins: Providers save time (no 'are you human?' loops), Payers reduce operational costs (faster calls), Patients get faster service, Compliance teams sleep better (clear audit trails)"

10.3 Navigation Structure (Inferred from static pages)

- Home (`index.html`)
- About (`about.html`)
- Specification (`specification.html`)
- Proof / Audit (`proof.html`)
- Simulator (`simulator.html`)
- FAQ (`faq.html`)
- Validation (`/validation/`) -- "Pilot Validation Program Now Live"

10.4 Messaging Hierarchy

1. **Headline problem:** Impersonation Latency -- the operational black hole
2. **The cost:** \$350B administrative complexity; AI-vs-AI friction making it worse
3. **The solution:** Four behaviors, binary testable, implementable today
4. **The proof:** Conformance test suite, cryptographic audit trails, compliance badges
5. **The path forward:** L1/L2/L3 certification, registry verification (v1.4+)

10.5 Compliance Badges (Embeddable)

```

```

Badge automatically goes dark if subscription lapses.

11. Whitepaper Content

11.1 Theory of Value

NHID-Clinical's value proposition operates at three levels:

Operational Value:

- Eliminates the "Are you human?" termination loop
- Reduces average handle time by 15-30 seconds per call
- Provides payers a standard for accepting (not just rejecting) AI callers

Compliance Value:

- Maps to HIPAA Minimum Necessary Standard (45 CFR § 164.502(b))
- Aligns with TCPA/FCC non-human voice disclosure requirements
- Supports NIST AI RMF GOVERN, MAP, MEASURE, MANAGE functions
- Addresses state law requirements (CA AB 489, CA AB 2905, NY S7263, Hawaii SB 2281)

Strategic Value:

- First-mover position in B2B healthcare voice AI governance
 - Open standard creates industry credibility; SaaS layer captures commercial value
 - Registry architecture (v1.4+) creates network effects as more vendors certify
-

11.2 Architecture Explanation

The NHID-Clinical platform has a deliberate two-layer architecture:

Open Standard Layer (CC BY 4.0):

- Voluntary governance proposal
- Deterministic policy engine
- Machine-readable conformance tests
- Published under permissive license to encourage adoption

Commercial Enforcement Layer (Private SaaS):

- Multi-tenant hosted enforcement platform
- Cryptographic audit trail (HMAC-SHA256 hash chain)
- Real-time webhook integration for voice providers
- Plan-gated features (Free/L1/L2/L3)
- Stripe billing

The two layers are deliberately separated: the open standard cannot be held hostage to commercial interests, and the commercial layer cannot undermine the standard's credibility.

11.3 Use Cases

Use Case 1: Prior Authorization AI

A provider practice deploys an AI voice agent (Retell AI) to call insurance companies for prior authorization. They integrate with NHID-Clinical SaaS via Retell webhook. Every call: (a) starts with disclosure, (b) policy enforces no PHI before disclosure, (c) escalation available, (d) cryptographic proof generated for compliance audit.

Use Case 2: Eligibility Verification

An RCM platform routes eligibility verification calls through NHID-Clinical. Policy engine detects if AI is requesting member ID before identifying itself. Payer can verify compliance via the SVG badge embedded on the vendor's website.

Use Case 3: Compliance Audit

A payer's compliance team needs to demonstrate that AI callers they interact with followed disclosure rules. They query the NHID-Clinical audit API for session proof. The cryptographic chain provides tamper-evident evidence.

Use Case 4: Bot-to-Bot Authorization

Two AI systems (provider AI + payer AI) are communicating. NHID-Clinical's bot-to-bot supplemental rule requires mutual disclosure before any data exchange.

11.4 Risks

Risk	Mitigation
Voluntary adoption -- payers don't require it	Start with provider-side adoption; build registry so payers have a standard to accept
Standard adoption without SaaS adoption	Open standard drives credibility; SaaS adds audit proof that the open standard alone can't provide
Competitor copies the standard	CC BY 4.0 license allows this; first-mover + registry + certification = durable advantage
Regulatory change makes standard obsolete	Standard is designed to complement (not replace) regulation; flexible enough to evolve
AI vendor doesn't support webhooks	All three major platforms (Retell, Vapi, Twilio) supported; Generic fallback
HMAC_SECRET compromise	Secret rotation procedure [Missing: not yet documented]

11.5 Differentiators

1. **Operational, not philosophical:** Binary pass/fail tests, not "ethical AI" guidelines
 2. **Built from real payer experience:** 8 months enforcing HIPAA compliance in actual payer operations
 3. **Deterministic and reproducible:** Policy engine is pure, no I/O, same inputs -> same outputs
 4. **Cryptographically auditable:** HMAC-SHA256 hash chain, not just logs
 5. **Provider-agnostic:** Works with Retell, Vapi, Twilio, or any webhook-capable platform
 6. **Open standard + commercial enforcement:** Credibility of open source + sustainability of SaaS
-

12. Diagrams & Visual Concepts

12.1 Compliant Call Flow

[Figure 1: Compliant Call Flow -- [nhid-clinical/assets/diagrams/compliant-call-flow.svg](#)]

Description: AI agent calls payer office. First utterance identifies as automated system. Payer verifies via registry (v1.4+). Data exchange proceeds. Call logged with cryptographic proof.

Purpose: Show the "Green Lane" -- what a conformant AI call looks like.

Placement: Homepage hero, whitepaper Section 2.

12.2 Non-Compliant Call Flow

[Figure 2: Non-Compliant Call Flow -- [nhid-clinical/assets/diagrams/non-compliant-call-flow.svg](#)]

Description: AI agent calls payer. Provides NPI and member ID before identifying as automated. Payer shares claim status. 3-5 minutes in, payer discovers AI. Call terminated. AI calls back. Loop repeats.

Purpose: Illustrate the Impersonation Latency problem.

Placement: Problem statement section, whitepaper.

12.3 Session Lifecycle

[Figure 3: Session Lifecycle -- [nhid-clinical/assets/diagrams/lifecycle.svg](#)]

Description: State machine diagram showing session states from `idle` through `AWAITING_DISCLOSURE` -> `DISCLOSED` -> `DATA_EXCHANGE_AUTHORIZED` or `GATE_BLOCKED` or `ESCALATING`.

12.4 NHID Workflow

[Figure 4: NHID Workflow -- [nhid-clinical/nhid-workflow.svg](#)]

Description: End-to-end workflow from call arrival through policy evaluation to audit persistence.

12.5 Architecture Diagram (Conceptual)

[Figure 5: NHID-Clinical SaaS Architecture -- Placeholder for production diagram]

```
Voice Provider (Retell/Vapi/Twilio)
  POST /saas/voice/webhook/incoming
```

```
SaaS Gateway (port 8010)
```

```
Voice Policy Engine
IDG-01  PDX-01
DBC-01  EIT-01  ATR-01
```

```
decision
```

```
Audit Chain Writer
HMAC-SHA256 + SHA256
Postgres append-only
```

```
HTTP response
{ action, reason_code, event_hash }
```

12.6 Certification Badge Visual

[Figure 6: NHID L1/L2/L3 Compliance Badges]

Static badge assets: `nhid-clinical/assets/badges/L1-baseline.png` , `L2-operational.png` , `L3-enterprise.png`

Dynamic SVG badges served at: `/saas/badge/{org_id}`

12.7 Policy Decision Flow (Code-Level)

```
evaluate_all(session, event)

    evaluate_atr01()    -> PolicyDecision
    evaluate_idg01()    -> PolicyDecision
    evaluate_pdx01()    -> PolicyDecision
    evaluate_dbc01()    -> PolicyDecision
    evaluate_eit01()    -> PolicyDecision
    evaluate_bot_to_bot() -> PolicyDecision

merge all violations
select dominant action (highest priority)
return composite PolicyDecision
```

13. Research References

13.1 Market & Industry Data

Source	Claim	Year
Health Affairs	U.S. health system administrative complexity costs \$350 billion annually	2025
Peterson Health Technology Institute	AI speeds up individual tasks but does not lower average cost per claim once AI solution costs factored in	April 2026
Medicare Advantage plans	82% overturn rate in prior auth appeals	Q2 2026

Source	Claim	Year
Payer operations data (inferred)	30-40% of administrative time for complex claims = human oversight of AI-generated billing	2026
Transaction data (inferred)	Single claim cycles through 3-4x more automated loops (appeals, resubmissions, denials) than in 2024	2026

Disclaimer from source: "The \$40M industry cost estimate" is labeled non-validated in v1.3. The above are from cited external sources.

13.2 Referenced Standards & Frameworks

Standard	Relevance
NIST AI RMF 1.0	Primary governance framework alignment (see Section 15)
ISO/IEC 42001:2023	International AI management standard alignment
RFC 2119	MUST/SHOULD/MAY terminology used throughout NHID-Clinical
HL7 FHIR	Technical binding for audit logging (NHID-Clinical Layer 3)
HIPAA (45 CFR § 164.502(b))	Minimum Necessary Standard -- PDX-01 alignment
TCPA (47 U.S.C. § 227)	Outbound call consent -- informational alignment
JSON Schema Draft 2020-12	NHID trace schema format
OpenAPI 3.1	SaaS API specification
Ed25519	Agent identity cryptography
HMAC-SHA256	Audit chain tamper-evidence

13.3 Linked External Resources

- NHID-Clinical public repo: <https://github.com/thankcheeses/NHID-Clinical>
- NHID-Clinical website: <https://nhid-clinical.org>
- NHID-Clinical validation: <https://nhid-clinical.org/validation/>
- Specification PDF v1.3: [nhid-clinical/spec/NHID-Clinical-v1.3-Core-Specification.pdf](#)
- Overview PDF v1.3: [nhid-clinical/spec/NHID-Clinical-v1.3-Overview.pdf](#)

- NIST AI RMF: <https://airc.nist.gov/RMF>
- HL7 FHIR AuditEvent: <https://hl7.org/fhir/auditevent.html>
- US NPI system URI: <http://hl7.org/fhir/sid/us-npi>

14. Regulatory & Federal Alignment

14.1 Federal Framework

TCPA -- 47 U.S.C. § 227

NHID-Clinical addresses B2B inbound handshake content in workflows not covered by TCPA's consumer-protection scope. TCPA governs outbound call consent; NHID-Clinical governs disclosure timing in B2B voice workflows.

FCC February 2024 Declaratory Ruling (Non-Human Voice)

Mapped to `healthcare_governance.disclosure_timestamp` in the NHID trace schema. The disclosure timestamp must be set before any data exchange.

HIPAA Minimum Necessary Standard -- 45 CFR § 164.502(b)

PHI categories accessed during each interaction must be logged in `healthcare_governance.phi_accessed`. Systems operating under HIPAA-aligned posture MUST populate this field. Note: NHID-Clinical is NOT a substitute for a BAA or organizational HIPAA compliance program.

14.2 State Laws

Law	State	Effect Date	NHID-Clinical Mapping
CA AB 489	California	Jan 1, 2026	Prohibits AI implying possession of healthcare license -> DBC-01 <code>license_claim</code> flag
CA AB 2905	California	Jan 1, 2026	AI identity disclosure in voice -> <code>disclosure_timestamp</code> + <code>identity_assertion_text</code>
NY S7263	New York	Advanced March 2026	Private right of action for AI impersonation -> <code>identity_assertion_text</code>
	Hawaii	Feb 2026	

Law	State	Effect Date	NHID-Clinical Mapping
Hawaii SB 2281			Qualified human oversight personnel requirement -> EIT-01 escalation gate
UT SB 226	Utah	Active	AI disclosure -> <code>disclosure_timestamp</code>
TX TRAIGA	Texas	Active	AI disclosure -> <code>disclosure_timestamp</code>

All regulatory mappings are **informational only**. NHID-Clinical does not create or extend legal obligations under any listed framework. Consult qualified legal counsel for compliance determinations.

14.3 FHIR Technical Mapping

Full FHIR mapping table from specification (Layer 3 -- informative):

NHID-Clinical Concept	FHIR Resource	Usage
Proactive Identity Assertion	<code>AuditEvent</code> + <code>Provenance</code>	<code>AuditEvent.occurredPeriod</code> proves disclosure before data exchange
Pre-Data Exchange Gate	<code>AuditEvent</code> sequence	Two correlated events: (1) disclosure, (2) data request
Agent & Organization ID	<code>AuditEvent.agent</code>	<code>agent.who</code> -> <code>Practitioner</code> / <code>Organization</code> with NPI identifier
Deceptive Artifacts	<code>AuditEvent</code> + Extension	Custom extension: <code>nhid-deceptiveArtifacts</code>
Escalation	<code>AuditEvent</code> + <code>Task</code> / <code>Communication</code>	Log escalation request, reference ID, outcome
Audit Trail	<code>AuditEvent</code> (primary)	Structured logging for every interaction

Use of FHIR is not required for L1 Baseline but strongly recommended for L2/L3 production evidence.

14.4 Documentation Expectations for Audit

Tier 1 (Minimum Required):

- Transaction log: "Identity Disclosed" timestamp vs. "Data Request" timestamp
- Script version control: documentation proving disclosure language was in production

Tier 2 (Recommended):

- Audio snippet: first 30 seconds of call recording (subject to retention policies)
- FHIR AuditEvent records (L2/L3)
- NHID-Clinical SaaS cryptographic proof via `/saas/audit/proof/{session_id}`

15. NIST References

15.1 NIST AI RMF Alignment Table

NHID-Clinical Control	NIST AI RMF 1.0 Function	Notes
Proactive Identity Assertion (IDG-01)	MEASURE 2.6 (Transparency); MAP 3.4 (Context)	Ensures stakeholders know they're interacting with AI before risk exposure
Turing Boundary / No Deception (DBC-01)	GOV 1.5 (Risk Management); MAP 3.4 (Human-AI Interaction)	Prevents manipulative design patterns (fake breathing)
Pre-Data Exchange Gate (PDX-01)	MANAGE 1.2 (Risk Treatment); GOV 5.1 (Legal Compliance)	Enforces Minimum Necessary data access
Safe Failover / Escalation (EIT-01)	MANAGE 4.2 (Human Oversight); GOV 5.2 (Feedback Loops)	Guarantees Human-in-the-Loop fallback
Audit Logging (ATR-01)	MANAGE 4.1 (Monitoring); MEASURE 2.2 (Validation)	Provides evidentiary chain for compliance audits

NHID-Clinical NIST Comment reference: **NIST-2025-0035-0026**

15.2 NIST AI RMF GOVERN Function Implementation

GOVERN 1.5 -- Risk Management Policies: DBC-01's prohibition of deceptive artifacts implements a concrete, testable policy for a specific AI risk (human impersonation in healthcare).

GOVERN 5.1 -- Legal Compliance: PDX-01 gate enforces data minimization aligned with HIPAA Minimum Necessary Standard.

GOVERN 5.2 -- Feedback Loops: EIT-01 escalation requirement ensures human feedback is available when AI fails.

15.3 NIST AI RMF MEASURE Function Implementation

MEASURE 2.2 -- Validation: The 43-test conformance suite and 18 YAML test cases provide machine-readable pass/fail validation.

MEASURE 2.6 -- Transparency: disclosure_timestamp and identity_assertion_text fields make AI transparency measurable and auditable.

15.4 NIST AI RMF MANAGE Function Implementation

MANAGE 1.2 -- Risk Treatment: PDX-01 DENY_DATA action is the concrete risk treatment for pre-disclosure PHI requests.

MANAGE 4.1 -- Monitoring: HMAC-SHA256 audit chain provides continuous, tamper-evident monitoring of every interaction.

MANAGE 4.2 -- Human Oversight: EIT-01 escalation gate guarantees a functional path to human oversight at any point in any call.

16. CMS References

16.1 CMS-Relevant Context

Prior Authorization Context:

The primary use case for NHID-Clinical is AI agents calling payer offices for prior authorization (PA) checks. CMS has been actively working to reduce administrative burden in PA workflows:

- CMS PA reform rules require payers to respond faster and provide reasons for denials
- AI-driven PA automation is growing rapidly, creating the exact Impersonation Latency problem NHID-Clinical addresses

- 82% overturn rate in Medicare Advantage PA appeals (Q2 2026) suggests systematic over-denial that AI appeals workflows are targeting

Medicare Advantage:

The high appeal overturn rate creates incentive for AI to file large volumes of appeals. NHID-Clinical provides the governance layer for when those AI-driven appeal calls reach human payer staff.

16.2 Healthcare Operations Implications

For Payer Operations:

- NHID-Clinical gives payer call centers a standard for when to accept vs. reject AI callers
- Compliance badge provides visual signal of certified AI behavior
- L1/L2/L3 tiers let payer staff calibrate trust level

For Revenue Cycle Management (RCM) Platforms:

- L2 webhook integration automates NHID compliance for every outbound call
- Cryptographic proof enables audit defense if questioned by payers

For Health IT Compliance:

- ATR-01 audit trail + HMAC chain provides documentation for HIPAA audit defense
 - FHIR AuditEvent mapping enables integration with existing compliance infrastructure
-

16.3 Reimbursement / Workflow Relevance

NHID-Clinical does not directly affect reimbursement decisions. It governs the communication channel through which those decisions are requested and delivered. By reducing Impersonation Latency:

- Fewer calls are terminated before useful data is exchanged
 - PA decisions may be reached faster (direct operational benefit)
 - Fraud vectors (AI spoofing provider identity to extract data) are reduced
-

17. Sponsorship & Partnership Discussions

17.1 Partner Ideas

[Missing: No formal partnership documents in repository. The following is inferred from source material.]

Natural partners:

- AI voice platform vendors (Retell AI, Vapi, Twilio) -- webhook integration partners
- Healthcare RCM platforms -- distribution channel
- EHR vendors integrating prior auth workflows
- Healthcare compliance software vendors
- HIPAA consulting firms

Institutional collaboration:

- NIST (already filed comment NIST-2025-0035-0026)
- HL7 (FHIR mapping layer)
- AHIP (America's Health Insurance Plans) -- payer association
- AMA (American Medical Association) -- provider advocacy
- MGMA (Medical Group Management Association) -- practice management

17.2 Pilot Validation Program

From website content: "First validations offered at no cost for AI voice agent platforms in healthcare."

Contact for validation: validation@nhid-clinical.org

Validation email: validation@nhid-clinical.org

General contact: contact@nhid-clinical.org / help@nhid-clinical.org

17.3 Open Source Collaboration

GitHub: <https://github.com/thankcheeses/NHID-Clinical>

CODEOWNERS: * [@thankcheeses](#)

License: CC BY 4.0 (open standard layer only)

Contribution pathways:

- GitHub Discussions for questions
- GitHub Issues for specific problems
- Direct email for validation and certification

18. Marketing & Positioning

18.1 Audience-Specific Messaging

For AI Voice Platform Vendors (Retell, Vapi, Twilio partners):

"Add NHID compliance to every call in 30 minutes. Drop-in webhook. Your AI agent automatically discloses its identity, logs every decision with a cryptographic hash, and triggers human escalation when requested. One URL. Three providers supported out of the box."

For Healthcare IT Teams:

"Prove your AI voice agent follows the rules -- with tamper-evident, cryptographically signed audit trails. When a payer asks 'did your AI disclose before asking for member ID?' -- you have the proof."

For Compliance Officers:

"NHID-Clinical maps directly to NIST AI RMF, HIPAA Minimum Necessary, and five state laws (CA, NY, HI, UT, TX). Binary pass/fail tests. Machine-readable conformance suite. FHIR-compatible audit logging. This is compliance you can actually audit."

For Payer Operations Staff:

"Finally, a standard for when to accept AI callers. NHID compliance badge on the URL. Cryptographic proof on demand. Green lane for compliant AI; clear rejection criteria for non-compliant calls."

For Investors:

"The \$350B healthcare administrative overhead is being automated by AI -- but AI-vs-AI friction is inflating costs, not reducing them. NHID-Clinical is the governance standard that makes AI-driven healthcare operations actually work. Open standard for credibility. SaaS enforcement for revenue. Registry architecture for network effects."

18.2 Technical Positioning

"NHID-Clinical is to healthcare voice AI what OAuth is to API authentication -- a standard that makes complex interactions safe, verifiable, and interoperable."

Key technical differentiators:

- Policy engine is pure Python, fully deterministic, reproducible
- HMAC-SHA256 hash chaining (not just logs)
- Append-only at the database trigger level
- Three webhook providers auto-detected and normalized
- Per-org configurable rulesets

18.3 Clinical Positioning

"Every minute spent verifying whether you're talking to a human or a robot is a minute not spent on patient care. NHID-Clinical ends that verification loop."

18.4 Differentiation Language

vs. General AI Governance Frameworks:

"NIST AI RMF tells you WHAT to govern. NHID-Clinical tells you exactly HOW to govern AI voice identity in healthcare -- with binary tests you can run today."

vs. Telephony Compliance Solutions:

"NHID-Clinical is not a call recording compliance tool. It's a real-time policy enforcement layer that decides, event by event, whether an AI agent is behaving correctly -- and writes a cryptographic proof of that decision."

vs. "Ethical AI" Initiatives:

"We don't ask you to think harder about AI ethics. We give you a test suite with 18 deterministic test cases and a webhook you can implement this week."

19. Decisions Made

19.1 Architecture Decisions

Decision	Rationale	Alternatives Considered
Direct Python import for NHID core (not HTTP)	Avoids Bridge HTTP overhead; core test suite isolated	HTTP proxy to port 8000 (Bridge) -- rejected: adds latency and coupling
PostgreSQL over SQLite for SaaS layer	SQLite evaporates on Replit container restart; data loss on every autoscale	SQLite -- rejected: lost data confirmed before migration
<code>pg_advisory_xact_lock</code> over <code>SELECT FOR UPDATE</code>	FOR UPDATE cannot lock non-existent rows; first-write race was	<code>SELECT FOR UPDATE</code> -- rejected: <code>test_concurrent_writes_same_org_no_collision</code> failed

Decision	Rationale	Alternatives Considered
	confirmed by test	
Append-only triggers at DB level	Application-level enforcement can be bypassed; trigger enforcement is stronger	Application-only enforcement -- rejected: less secure
HMAC-SHA256 over a simple hash	HMAC requires secret key knowledge to forge; plain SHA256 does not	Plain SHA256 -- rejected: not tamper-evident without secret
Plan-gate voice webhooks at L2+	Live telephony integration represents real operational deployment, not just API access	Include in L1 -- rejected: would undervalue L2 and under-price operational deployments
pnpm 1440-min release age gate	Supply chain attack vector: fresh npm packages can be compromised	No age gate -- rejected: security risk

19.2 Design Decisions

Decision	Rationale
Glassmorphism dark design system	Professional, distinctive healthcare tech aesthetic; distinguishes from generic SaaS
#070c17 background	Deep dark tone appropriate for compliance-focused product
Teal #00c2a8 primary	Healthcare associations; distinctive in dark context
Raleway font	Clean, professional; readable at small sizes
SVG compliance badges (not image)	Scalable, embeddable anywhere, can be dynamically served
Badge goes dark on lapse	Prevents stale trust signals; creates real subscription value

19.3 Standard Design Decisions

Decision	Rationale
Pre-Data Exchange gate over time-based disclosure	"3-second window" fails in laggy VoIP; data-first gate is auditable and technology-agnostic
B2B only (no B2C) in v1.3	Deliberate: B2C has materially different regulatory considerations; B2B provides deep validation first
Voluntary proposal, not regulatory mandate	Builds adoption faster; avoids regulatory friction while market develops
Five discrete conformance tests (not a scoring rubric)	Binary pass/fail is more actionable than scoring; auditors need yes/no answers
CC BY 4.0 for open layer	Maximizes adoption; commercial advantage comes from enforcement layer and registry, not IP lock

19.4 Unresolved Questions

Question	Status
CORS: should <code>allow_origins=["*"]</code> be restricted?	[Needs Review] -- overly permissive for production

Question	Status
Agent revocation: should <code>revocation_list</code> persist across restarts?	[Open Question]
HMAC_SECRET rotation procedure	[Missing -- not yet documented]
Admin credentials: <code>nhidclinical1626</code> default password	[Needs Review -- should be forced to change on first deploy]
Full git branching strategy	[Missing]
Public registry infrastructure design (v1.4+)	[Open Question]

20. Future Work

20.1 v1.4 Features (Planned)

1. **Live Registry** -- public verification layer for certified implementations. Enables real-time AI caller authorization checks.
2. **NHID-Auth v1.0 (companion spec)** -- delegated authority verification for AI voice agents. JWT handshake implementation.
3. **Multilingual support** -- extend standard to non-English B2B workflows
4. **Outbound call guidance (payer-initiated)** -- currently out of scope in v1.3
5. **Technical implementation bindings** -- OpenTelemetry event schema, OPA/Cedar policy engine integration guides
6. **Pilot certification program** -- first L1/L2 certifications for 2-3 early vendors

20.2 Open Engineering Items

1. Restrict CORS from `allow_origins=["*"]` to known frontend origin
2. Persistent agent revocation storage (currently in-memory)
3. HMAC_SECRET rotation procedure
4. Admin password force-change on first deploy
5. Full production load testing of advisory lock under high concurrency
6. Rate limiting for `/saas/orgs/register` (currently unrestricted)

7. `stripe_price_ids.json` -- verify all plan IDs are seeded correctly
-

20.3 Standard Evolution Items

1. **Patient-facing workflows** -- direct-to-consumer or clinical triage
 2. **Multi-entity integrations** -- complex scenarios with multiple payers/vendors
 3. **Accessibility** -- multilingual, deaf/hard-of-hearing accommodations
 4. **International compliance** -- GDPR and non-U.S. regulatory contexts
 5. **Outbound payer-initiated calls** -- currently out of v1.3 scope
 6. **Technical runtime bindings** -- OpenTelemetry, OPA/Cedar
-

20.4 Research Needs

1. Adoption measurement: how many AI voice platforms call payer offices per day?
 2. Impersonation Latency measurement: what is the average delay to disclosure in current deployments?
 3. Cost quantification: validated estimate of administrative waste from AI-vs-AI friction
 4. Payer acceptance rates: what percentage of payers have written AI call acceptance policies?
 5. State law tracking: monitor emerging legislation (CA, NY, HI, UT, TX and others)
-

21. Templates & Checklists

21.1 Production Deployment Checklist

NHID-Clinical SaaS Production Launch Checklist

NHID CORE INTEGRITY

- [] `python -m pytest tests/ -v -> 25 passed, 18 skipped`
- [] No modifications to: `app.py`, `nhid_engine.py`, `nhid_policy.py`, `nhid_event_store.py`, `tests/`, `src/`, `schema/`, `pytest.ini`, `requirements.txt`, `twilio_helper.py`, `llm.py`

STRIPE CONFIGURATION

- [] `STRIPE_SECRET_KEY` is `sk_live_*` (not `sk_test_*`)
- [] `STRIPE_WEBHOOK_SECRET` is configured
- [] Webhook endpoint registered in Stripe dashboard: `/saas/billing/webhook`
- [] Webhook events configured: `checkout.session.completed`, `invoice.paid`, `customer.subscription.updated`, `customer.subscription.deleted`

ENVIRONMENT VARIABLES

- [] `DATABASE_URL` set (Replit PostgreSQL)
- [] `HMAC_SECRET` set (not empty)
- [] `ADMIN_USER` set (not default "admin")
- [] `ADMIN_PASS` set (not default "nhidclinical1626")
- [] `SAAS_ADMIN_KEY` set (not default "nhid-admin-key-dev")

ARCHITECTURE VERIFICATION

- [] No `localhost:8001` references anywhere in production code
- [] No Bridge service dependency
- [] No HTTP calls between SaaS and NHID Core
- [] SaaS Gateway is the ONLY backend control plane

SECURITY

- [] Admin endpoints require `X-Admin-Session` header
- [] No debug routes accessible in production
- [] Stripe webhook signature validation enabled
- [] CORS restricted to frontend origin (NEEDS REVIEW -- currently *)

FRONTEND

- [] `Raleway` font loaded
- [] Dark theme active (`#070c17` background)
- [] Teal primary (`#00c2a8`) active
- [] No debug UI, dev logs, or placeholder content
- [] Routes working: `/`, `/dashboard`, `/usage`, `/trace`, `/proof`, `/billing`, `/admin`, `/audit`

ACCEPTANCE CRITERIA

- [] 43/0/0 NHID tests unchanged
- [] Stripe checkout completes successfully
- [] Webhook updates org status to active
- [] API blocked when inactive (402 returned)
- [] Admin login works via env credentials
- [] No Bridge / 8001 dependency anywhere
- [] System runs as single backend SaaS gateway

21.2 Conformance Self-Assessment Checklist

NHID-Clinical v1.3 Conformance Self-Assessment

IDG-01: Identity Disclosure Gate

- ☐ AI discloses "I am an automated system" (or equivalent) before any data exchange
- ☐ disclosure_timestamp is set at first utterance
- ☐ identity_assertion_text contains verbatim disclosure statement

PDX-01: Pre-Data Exchange Gate

- ☐ No NPI, Member ID, DOB, Claim Number, etc. requested before disclosure
- ☐ System blocks data requests if disclosure_timestamp is null

DBC-01: Deceptive Behavior Check

- ☐ No synthetic breathing in audio
- ☐ No fake typing sounds
- ☐ No artificial hesitation designed to imply human presence
- ☐ No human name without AI qualifier
- ☐ No claim of licensed professional status

EIT-01: Escalation Implementation Test

- ☐ Transfer to human available during business hours
- ☐ Escalation triggers correctly on trigger phrases
- ☐ After-hours: hours stated + callback offered
- ☐ No infinite "I didn't understand" loops
- ☐ Context (reference number) preserved on transfer

ATR-01: Audit Trail Requirements

- ☐ All required audit fields present (event_id, timestamp, session_id, request_id, event_type, actor_id, state_before, state_after, replay_mode, external_calls_cached)
- ☐ execution_context fields present (pipeline_version, policy_engine_version, nhid_schema_version)

21.3 New Org Onboarding Template

NHID-Clinical SaaS Onboarding Flow

1. Register org
POST /saas/orgs/register
{ "org_name": "<your org name>" }
-> save api_key from response
2. Check your plan
GET /saas/orgs/me
Header: X-API-Key: <api_key>
3. Test the API
POST /saas/voice/incoming
Header: X-API-Key: <api_key>
Body: { "caller_id": "test-call-001" }
-> save session_id from response
4. Process a transcript
POST /saas/voice/transcript
Header: X-API-Key: <api_key>
Body: { "session_id": "<id>", "transcript_text": "Can I get the member ID?",
"turn_number": 1 }
-> check action in response (should be "disclose" -- disclosure not yet confirmed)
5. Get proof
GET /saas/proof/<session_id>
Header: X-API-Key: <api_key>
-> verify chain_valid = true
6. Upgrade plan (L2 for live voice webhooks)
POST /saas/billing/checkout
Body: { "plan": "l2", "success_url": "...", "cancel_url": "..." }
-> redirect to Stripe checkout
7. Configure voice webhook in Retell/Vapi/Twilio
Incoming: https://<domain>/saas-api/saas/voice/webhook/incoming?api_key=<key>
Transcript: https://<domain>/saas-api/saas/voice/webhook/transcript?api_key=<key>

21.4 Governance Review Checklist

NHID-Clinical Governance Review Checklist (Quarterly)

POLICY ENGINE INTEGRITY

- ☐ nhid_policy_engine_v1.py has not been modified
- ☐ All five conformance tests passing (IDG-01, PDX-01, DBC-01, EIT-01, ATR-01)
- ☐ Bot-to-bot supplemental rule active

AUDIT CHAIN INTEGRITY

- ☐ Run /saas/audit/verify/ on sample of recent sessions
- ☐ chain_valid = true for all verified sessions
- ☐ hmac_valid = true for all verified sessions
- ☐ No breaks[] entries in sample

BILLING & ACCESS CONTROL

- ☐ All active orgs have valid Stripe subscriptions
- ☐ No orgs with status="active" and no subscription_id (except free tier)
- ☐ Plan gates enforced: voice webhooks blocked for free/L1

VOICE SESSION HEALTH

- ☐ Review escalated sessions: GET /admin/voice/sessions?escalated_only=true
- ☐ Review undisclosed sessions: GET /admin/voice/sessions?undisclosed_only=true
- ☐ Session TTL configured appropriately per org

SECURITY

- ☐ HMAC_SECRET has not been rotated without audit chain migration
- ☐ Admin session log reviewed
- ☐ No unauthorized admin logins
- ☐ Append-only triggers verified on audit_traces

STANDARD VERSION

- ☐ Running NHID-Clinical spec version: 1.3
- ☐ Policy engine version: 1.0.0
- ☐ Schema version: 1.0

22. FAQ & Plain Language Guide

22.1 What is NHID-Clinical in one sentence?

It's a rulebook -- and an enforcement system -- that requires AI voice agents to identify themselves before asking for any health insurance information.

22.2 Why does this need to exist? Isn't this obvious?

It should be obvious -- but it isn't happening. AI agents are calling insurance companies right now, collecting claim data and eligibility information, and only saying "by the way, I'm a robot" when directly asked. By then, the payer rep has already shared protected data. There's no standard for what a legitimate AI call looks like, so payers just hang up on all of them.

22.3 What are the four rules?

1. Say you're an AI before asking for anything
 2. No fake human sounds (breathing, typing, "umm")
 3. Transfer to a human immediately when asked
 4. Keep a log of what happened
-

22.4 Who is this for?

Companies that build AI voice agents that call health insurance companies. Also: the insurance companies receiving those calls, who need a standard for when to accept them.

22.5 Is this a law?

No. It's a voluntary standard. But it aligns with several laws that are active or becoming active: California, New York, Hawaii, Utah, and Texas all have relevant legislation.

22.6 What's the difference between the open standard and the SaaS product?

The open standard (free, CC BY 4.0, on GitHub) defines the rules and provides a policy engine you can run yourself. The SaaS product hosts that enforcement for you, adds cryptographic proof that can't be tampered with, integrates with Twilio/Retell/Vapi directly, and handles billing. The standard is the credibility; the SaaS is the commercial product.

22.7 What is "Impersonation Latency"?

The time gap between when an AI starts a call and when it discloses it's an AI. Even 30 seconds is too long if the payer rep has already given out claim information. NHID-Clinical eliminates this by requiring disclosure before any data exchange -- not after.

22.8 What is a "compliance badge"?

An SVG image your company can embed on its website. It says "NHID L2 Verified -- [Your Company Name]" and is served dynamically. If your subscription lapses, the badge disappears automatically. Payer staff can check the badge before sharing data with an AI caller.

22.9 What happens if the AI fails a test?

- IDG-01 fail (no disclosure): AI is required to say "I am an automated system" before proceeding
 - PDX-01 fail (PHI before disclosure): Data request is denied. AI must disclose first.
 - DBC-01 fail (fake sounds): Violation logged. Call continues but flag is permanent in the audit trail.
 - EIT-01 fail (no escalation path): Caller told "I cannot transfer you at this time" -- and that failure is logged.
 - ATR-01 fail (missing audit fields): Event logged with violation. Audit trail is flagged incomplete.
-

22.10 What is a "tamper-evident audit trail"?

Every event in a call is signed with a secret key. Each event also includes a hash of the previous event. If anyone modifies a past event, all subsequent hashes break. You can verify the entire chain with one API call. This is the same concept used in blockchains, but simpler and purpose-built for compliance logging.

22.11 What does "deterministic policy engine" mean?

Given the same call transcript and session state, the policy engine always makes the same decision. No randomness. No AI guessing. This is essential for compliance: you can replay any historical call and get the same governance decision.

23. Source Material Appendix

23.1 File Inventory (Complete)

Total files: ~358

Key categories: TypeScript/JavaScript (~120), Python (~80), YAML/JSON (~20), HTML/CSS (~50), Markdown/Docs (~15), SVG/Images (~20), Git/Config (~30), Lock files (~3), PDF/Binary (~2)

23.2 NHID Policy Engine v1 -- Canonical PolicyDecision Structure

```
@dataclass
class PolicyDecision:
    action: PolicyAction # DISCLOSE_IDENTITY | ESCALATE_HUMAN |
    CONTINUE_AI | DENY_DATA | LOG_ONLY
    reason_code: str # e.g. "IDG01_DISCLOSURE_CONFIRMED"
    policy_version: str # POLICY_ENGINE_VERSION = "1.0.0"
    violations: list[BoundaryViolation]
    next_state: str # e.g. "DISCLOSED", "GATE_BLOCKED"
    twiml_fallback: str | None # Deterministic TwiML XML when policy
    requires scripted response
    gather_speech: bool # Whether TwiML should include Gather verb

    def has_critical_violations(self) -> bool:
        return any(v.severity == ViolationSeverity.CRITICAL for v in self.violations)
```

23.3 Canonical Audit Payload Format

```
# From saas_layer/audit.py
_PAYLOAD_KEYS = (
    "event_type",
    "state_before",
    "state_after",
    "input_text",
    "policy_action",
    "reason_code",
    "response_text",
    "policy_version",
    "model_version",
)

# Hash computation:
# event_hash = SHA256(canonical_json_bytes + prev_hash_hex_utf8_bytes).hexdigest()
# canonical_json = json.dumps(payload_dict, sort_keys=True, separators=(',', ':'))

# HMAC computation:
# hmac_input = event_hash_hex + org_id + timestamp_iso + (policy_version or "") +
# str(seq_num)
# hmac_signature = HMAC-SHA256(HMAC_SECRET_bytes, hmac_input_utf8_bytes).hexdigest()

# Genesis hash: "0" * 64
```

23.4 Voice Policy Default Ruleset

```
DEFAULT_RULESET = [  
    {  
        "rule_key": "REQUIRE_UPFRONT_DISCLOSURE",  
        "rule_type": "builtin",  
        "label": "Upfront AI Disclosure",  
        "enabled": True,  
        "priority": 0,  
        "params": {},  
    },  
    {  
        "rule_key": "HUMAN_ESCALATION_REQUESTED",  
        "rule_type": "phrase_match",  
        "label": "Human Escalation Trigger",  
        "enabled": True,  
        "priority": 1,  
        "params": {  
            "phrases": [  
                "speak to a human", "real person", "agent please",  
                "transfer me", "human agent", "talk to someone",  
            ]  
        },  
    },  
]
```

23.5 PHI Fields (PDX-01)

```
_PHI_REQUEST_TRIGGERS = frozenset({  
    "member_id", "npi", "date_of_birth", "claim_number",  
    "prior_auth_number", "diagnosis_code", "procedure_code", "provider_tin",  
})  
  
_PHI_SPEECH_PATTERNS = (  
    "member id", "member number", "date of birth", "dob",  
    "claim number", "authorization number", "prior auth",  
    "npi number", "tax id", "tin",  
    "diagnosis", "procedure code", "icd",  
)
```

23.6 Deceptive Artifact Categories

Prohibited flags (structured):

```
fake_breathing, fake_typing, artificial_pause, human_name_claim, license_claim,  
employer_claim_unverified
```

Prohibited transcript markers:

```
[breathing], [typing], [sigh], [keyboard]
```

Additional DBC-01 detection:

```
session_state["human_name_used"] AND NOT session_state["ai_qualifier_present"]
```

23.7 Production Launch Final Constraints (verbatim from source)

CONSTRAINTS (NON-NEGOTIABLE):

- NHID Core (port 8000) MUST NOT be modified
 - NHID Core tests MUST remain 43/0/0
 - NO changes to tests/
 - NO reintroduction of Bridge service or HTTP dependency to internal core
 - SaaS Gateway is the ONLY backend control plane
 - All production logic must live in SaaS layer only
-

23.8 Agent Memory Index (verbatim from MEMORY.md)

```
- SaaS layer architecture -- SaaS gateway accesses NHID via HTTP ONLY through Bridge (port 8001)
  using nhid_client.py; no direct Python imports from NHID core modules.
  [NOTE: This note is OUTDATED -- current architecture uses direct imports, not HTTP Bridge]
- Port assignments -- Fixed port map for all services in this project.
- NHID core constraint -- app.py/nhid_engine/nhid_policy/nhid_event_store/tests are read-only;
  only saas_layer/ and new files allowed.
- Stripe Python SDK v15 quirks -- StripeClient(key), client.v1.* namespace, params as dicts, metadata.to_dict() not dict()/.get().
- NHID Clinical dark design system -- approved glassmorphism tokens; force .dark class via
  useEffect in App.tsx; Raleway font; bg #070c17; teal #00c2a8; cyan #53d8fb.
- NHID proof events access bug -- proof.trace is { events: [...] } not a flat array;
  access via (proof.trace as any)?.events, not Array.isArray(proof.trace).
- SaaS DB now PostgreSQL -- saas_layer fully migrated from SQLite to Replit PostgreSQL;
  db.py is the single connection module; psycopg2-binary in requirements.txt;
  %s placeholders; append-only triggers on audit_traces preserved as Postgres functions.
- Audit chain concurrent write bug -- SELECT FOR UPDATE cannot lock non-existent rows;
  use pg_advisory_xact_lock(hashtext(org_id)) instead to serialize first-insert races.
- Public reference vs paid-tier test split -- public NHID-Clinical repo gets only the pure
  policy engine + pure unit tests; SaaS-coupled & plan-gate tests stay in private NHID-Clinical-SaaS.
```

**** Conflict note:**** The `saas-layer.md` memory file states "SaaS gateway accesses NHID via HTTP ONLY through Bridge." This conflicts with the current gateway.py implementation which uses direct Python imports. The memory file represents an earlier architectural design. Current production architecture uses direct imports. The memory file should be updated.

23.9 FHIR AuditEvent Examples (Verbatim from Specification)

Compliant Disclosure + Data Request:

```

{
  "resourceType": "AuditEvent",
  "id": "nhid-compliant-call-20260503-001",
  "meta": {
    "profile": ["https://nhid-clinical.org/fhir/StructureDefinition/nhid-auditevent-disclosure"]
  },
  "action": "E",
  "recorded": "2026-05-03T14:22:45.123Z",
  "agent": [
    {
      "type": {
        "coding": [{ "code": "automated-voice-agent", "display": "Automated Voice Agent" }]
      },
      "who": {
        "identifier": {
          "system": "https://nhid-clinical.org/agent",
          "value": "agent-xyz-789"
        }
      },
      "requestor": false,
      "extension": [
        {
          "url": "https://nhid-clinical.org/fhir/Extension/nhid-compliance-level",
          "valueCode": "L2"
        }
      ]
    }
  ],
  "entity": [
    {
      "type": { "text": "VoiceCallSession" },
      "detail": [
        {
          "type": "nhidDisclosureStatement",
          "valueString": "Hello, this is an automated system calling on behalf of Dr. Smith's Dental Office, NPI 1234567890."
        },
        {
          "type": "nhidDisclosureTimestamp",
          "valueDateTime": "2026-05-03T14:22:41Z"
        },
        {
          "type": "nhidFirstDataRequestTimestamp",
          "valueDateTime": "2026-05-03T14:22:48Z"
        }
      ]
    }
  ]
}

```

```
]
}
```

23.10 Spec Version Constants

```
NHID_SPEC_VERSION = "1.3"
POLICY_ENGINE_VERSION = "1.0.0"
NHID_SCHEMA_VERSION = "1.0"
```

23.11 Known Test Session Output (from attached_assets)

From `Pasted--test-session-starts--1780051603208.txt` :

[Content: test session start transcript captured during development -- raw session output available in attached_assets directory]

From `Pasted-PS-C-Users-bnbay-NHID-Clinical-test-python-m-pytest-*` :

[Content: Windows PowerShell pytest run confirming 25 passed, 18 skipped]

23.12 Changelog Entry -- PostgreSQL Migration

```
Data migrated: 2026-05-29
All SQLite rows from saas.db copied to Postgres.
SQLite file still exists at nhid-clinical/saas.db but is no longer read or written by
any code.
Rule: never re-introduce sqlite3 in any saas_layer module.
```

End of NHID-Clinical Master Knowledge Archive v1.0

*Document compiled 2026-06-12 from 358 source files across NHID-Clinical-SaaS repository.
All material traceable to source. Inferred content labeled [Inferred]. Gaps labeled [Missing] or [Open Question].*

Author of underlying work: Brianna Baynard | contact@nhid-clinical.org | NIST-2025-0035-0026